

SPÉCIFICATION PRODUIT ET ARCHITECTURE

Assistant IA sécurisé pour l'entreprise

Cahier des charges fonctionnel et technique de référence pour un SaaS B2B multi-tenant, multi-IdP et respectueux des ACL.

Security by design

Clean Architecture

Multi-tenant

Zero Trust

RAG traçable

Extensible

Produit : AssistantCore

Version : 1.0 – Baseline de réalisation

Date : 22 juillet 2026

Statut : Spécification cible approuvable

Classification : Interne / Confidentiel

0. Contrôle du document

Champ	Valeur
Finalité	Définir l'ensemble du produit, les comportements attendus, l'architecture cible, les exigences non fonctionnelles et l'ordre optimal de réalisation.
Public	Product Owner, architectes, développeurs backend et frontend, ingénieurs plateforme, sécurité, QA, opérations et support.
Périmètre	Du socle d'identité jusqu'à l'exploitation en production : administration, connecteurs, ingestion, recherche, RAG, conversations, sécurité, facturation, observabilité et déploiement.
Hors périmètre	Conception graphique détaillée, contrats commerciaux, avis juridique formel, implémentation ligne par ligne et choix définitif de chaque fournisseur cloud.
Autorité	Ce document constitue la baseline produit. Toute dérogation structurante doit être documentée par une décision d'architecture et approuvée.

AVERTISSEMENT DE GOUVERNANCE

Les sections RGPD, conservation et conformité définissent des exigences d'ingénierie. Elles doivent être validées par le responsable sécurité, le DPO et le conseil juridique avant mise en production dans chaque juridiction.

Légende de livraison

EXISTANT : présent dans le dépôt

MVP : requis avant pilote client

ÉVOLUTION : prévu après validation du MVP

CRITIQUE : bloque la production

Table des matières

1. Synthèse exécutive	4. Architecture globale
1.1 Vision et proposition de valeur	4.1 Style recommandé
1.2 Principes non négociables	4.2 Couches et dépendances
1.3 Personas et cas d'usage	4.3 Composants d'exécution
2. Périmètre produit	4.4 Modèle de données cible
2.1 Capacités et versions	5. Architecture multi-tenant
2.2 Parcours de bout en bout	5.1 Résolution et isolation
2.3 Glossaire	5.2 Cycle de vie d'un tenant
3. État actuel et cible	6. Identité et authentification
3.1 Inventaire observé	6.1 Microsoft Entra ID
3.2 Analyse des écarts	6.2 Abstraction multi-IdP
	6.3 Bootstrap et JIT

6.4 Contexte utilisateur	12.1 Recherche hybride
7. Autorisation, rôles et ACL	12.2 Ranking et filtres
7.1 RBAC produit	13. Intelligence artificielle et RAG
7.2 ACL des sources	13.1 Génération et citations
7.3 Politiques d'autorisation	13.2 Sécurité IA
8. Administration du tenant	13.3 Fournisseurs et modèles
8.1 Organisations et paramètres	14. Conversations
8.2 Membres et invitations	15. Audit et journalisation
8.3 Licences et facturation	16. Sécurité et conformité
9. Contrat API et comportements transverses	16.1 Modèle de menaces
9.1 Catalogue des endpoints	16.2 Vie privée et RGPD
9.2 Validation et erreurs	17. Infrastructure et environnements
10. Plateforme de connecteurs	17.1 CI/CD et releases
10.1 Contrat commun	17.2 Sauvegarde et reprise
10.2 Graph, SharePoint et OneDrive	18. Observabilité et exploitation
10.3 SQL Server, PostgreSQL et Oracle	19. Performance et scalabilité
10.4 REST, ERP et CRM	20. Stratégie de tests
11. Ingestion et synchronisation	21. Roadmap de développement
11.1 Pipeline	22. Risques et décisions
11.2 Versionnement et déduplication	23. Définition de terminé
11.3 Suppression et réconciliation	24. Références
12. Recherche sécurisée	

1. Synthèse exécutive

1.1 Vision et proposition de valeur

AssistantCore est un SaaS B2B qui permet à un employé d’interroger en langage naturel les connaissances de son entreprise et d’obtenir une réponse explicable, accompagnée de citations, sans jamais élargir ses droits d’accès. Le produit réunit des sources hétérogènes dans une expérience conversationnelle unique, tout en maintenant l’organisation cliente comme frontière de sécurité.

La valeur n’est pas seulement la génération de texte. Le produit doit résoudre quatre problèmes simultanément : connecter les systèmes d’entreprise, conserver leurs permissions, retrouver les bons éléments avec une latence acceptable et produire une réponse dont l’utilisateur peut vérifier l’origine. Une réponse non sourcée, issue d’un contenu non autorisé ou impossible à auditer est considérée comme un échec produit.

0

fuite inter-tenant ou contournement d’ACL toléré

100 %

des affirmations factuelles importantes reliées à une source lorsque le mode sourcé est utilisé

< 5 s

objectif de première réponse visible pour une requête standard, hors dépendance externe dégradée

99,9 %

objectif initial de disponibilité mensuelle de l’API interactive

1.2 Principes non négociables

Principe	Conséquence de conception	Validation
Autorisation hors du modèle	Le LLM ne décide jamais si une donnée est accessible. Le backend filtre avant récupération et avant construction du contexte.	Tests négatifs d’ACL et traçage des documents retenus.
Isolation par défaut	Toute donnée persistée porte une organisation propriétaire ou appartient explicitement au plan de contrôle global.	Revue de schéma et tests inter-tenant automatisés.
Moindre privilège	Les comptes de connecteur, rôles et accès plateforme n’obtiennent que les droits requis.	Revue périodique des permissions et secrets.
Traçabilité	Les changements administratifs, synchronisations, recherches sensibles et accès aux sources sont corrélables.	Audit consultable, exportable et non modifiable par un tenant.
Extensibilité encadrée	IdP, connecteurs, moteur de recherche, embeddings et LLM sont derrière des contrats stables.	Tests contractuels et absence de type fournisseur dans le domaine métier.

Principe	Conséquence de conception	Validation
Dégradation sûre	En cas d'incertitude sur un tenant, une ACL, un secret ou une source, le système refuse ou s'abstient.	Scénarios de panne et chaos tests ciblés.
Suppression vérifiable	La suppression à la source ou par l'utilisateur se propage aux index, caches, conversations et sauvegardes selon la politique.	Rapport de purge et tests de réconciliation.

RÈGLE ABSOLUE

Aucun prompt système, garde-fou textuel ou instruction au modèle ne peut remplacer un contrôle d'autorisation déterministe. Une donnée non autorisée ne doit jamais apparaître dans le contexte envoyé au fournisseur IA, même si celui-ci promet de ne pas l'utiliser.

1.3 Personas et cas d'usage prioritaires

Persona	Objectif	Capacités principales	Limites
Employé	Trouver une réponse fiable sans connaître l'emplacement des documents.	Chat, citations, historique personnel, favoris, recherche de conversations, feedback.	Uniquement les sources et documents autorisés.
Manager	Utiliser l'assistant et suivre l'adoption de son périmètre.	Capacités employé, lecture des membres, rapports agrégés autorisés.	Ne configure pas les secrets ni les rôles élevés par défaut.
TenantAdmin	Configurer l'organisation et contrôler les accès.	Membres, invitations, rôles, connecteurs, paramètres, audit, politiques de conservation.	Ne peut pas administrer un autre tenant ni consulter les prompts privés sans base légitime.
Administrateur plateforme	Exploiter le SaaS et assister les clients.	Santé globale, support encadré, suspension, quotas et incidents.	Accès au contenu client désactivé par défaut, temporaire, justifié et audité.
Responsable sécurité / DPO	Vérifier contrôles, conservation et incidents.	Exports d'audit, politiques, rapports de suppression, preuves de contrôle.	Accès selon rôle séparé et principe du besoin de savoir.
Ingénieur connecteur	Ajouter une source sans modifier le cœur.	SDK interne, contrats de synchronisation, tests de conformité, télémétrie standard.	Pas d'accès direct aux données d'un tenant hors environnement autorisé.

Cas d'usage critiques

1. Un employé se connecte via son IdP, est admis dans un tenant connu et reçoit son contexte applicatif.
2. Un administrateur autorise une source SharePoint, sélectionne son périmètre et suit l'indexation.
3. Un utilisateur pose une question, la recherche applique tenant et ACL, puis le modèle répond avec citations.
4. Une permission est retirée à la source ; l'accès cesse dans le délai contractuel et la réconciliation confirme la purge.
5. Une synchronisation échoue ; elle reprend sans doublon, expose sa cause et alerte au bon niveau.

2. Périmètre produit

2.1 Capacités et versions

Domaine	MVP pilote	Production générale	Évolutions
Identité	Entra ID multi-tenant, tenant allowlist, JIT contrôlé.	Invitations, désactivation, groupes, politiques d'admission.	OIDC générique, SAML via broker, SCIM.
Administration	Organisation, membres, rôles, connecteurs, audit de base.	Paramètres, politiques, quotas, rapports d'usage.	Délégation avancée, rôles personnalisés.
Sources	SharePoint et OneDrive entreprise.	Microsoft Graph complet, SQL Server, REST.	PostgreSQL, Oracle, ERP et CRM dédiés.
Ingestion	Initiale, incrémentale, ACL, suppression, reprise.	Réconciliation, versionnement complet, backfill contrôlé.	Ingestion temps quasi réel et règles par type de contenu.
Recherche	Hybride, filtres tenant/ACL, citations.	Reranking, feedback, tuning par tenant.	Recherche fédérée, multimodale.
IA	Un fournisseur principal et un modèle de secours, réponses sourcées.	Registre de modèles, évaluation continue, coûts et quotas.	Routage intelligent, modèles privés/dédiés.
Conversation	Créer, consulter, renommer, supprimer.	Favoris, recherche, export et partage sécurisé.	Espaces d'équipe et workflows agentiques contrôlés.
Commercial	Entitlements et quotas configurables manuellement.	Catalogue d'offres, comptage fiable, intégration facturation.	Marketplace et facturation à l'usage avancée.

DÉCISION PRODUIT

Le premier écran utilisateur peut rester centré sur le prompt, mais une console d'administration distincte est indispensable. Elle est visible uniquement aux rôles autorisés et sert à connecter les sources, gérer les admissions, suivre les synchronisations et consulter l'audit.

2.2 Parcours de bout en bout

PARCOURS PRINCIPAL UTILISATEUR

1. Connexion
SSO de l'entreprise



2. Bootstrap
Tenant, membre, rôles



3. Question
Prompt et conversation



4. Recherche
Tenant + ACL + ranking



5. Réponse
Streaming + citations

Le frontend acquiert un jeton d'accès destiné à l'API, appelle le endpoint de bootstrap, puis initialise l'interface selon les permissions retournées. À chaque question, le backend reconstruit le contexte de sécurité depuis l'identité authentifiée ; il n'accepte jamais un identifiant de tenant ou de membre comme autorité provenant du navigateur.

Parcours administrateur



2.3 Glossaire

Terme	Définition normative
Tenant / organisation	Client logique et frontière d'isolation des données, de configuration, de facturation et d'autorisation.
IdP	Fournisseur d'identité authentifiant une personne ou une charge de travail : Entra ID, Okta, Auth0, Keycloak, etc.
JIT	Provisionnement « just in time » d'un membre lors d'une connexion autorisée, selon une politique d'admission déterministe.
RBAC	Autorisations sur les fonctions du produit, dérivées de rôles tels que TenantAdmin, Manager ou User.
ACL	Liste de contrôle d'accès issue d'une source et attachée aux objets indexés ; elle détermine qui peut retrouver le contenu.
Principal	Identité autorisable : utilisateur, groupe, application ou pseudo-principal documenté.
Connecteur	Adaptateur d'une source externe vers le contrat commun d'authentification, découverte, synchronisation, ACL et santé.
RAG	Génération augmentée par récupération : sélection de contenus autorisés, construction du contexte et génération d'une réponse.
Chunk	Fragment indexable d'un document, conservant le lien vers le document, la version, la position et les ACL effectives.
Plan de contrôle	Administration, configuration et orchestration du SaaS.
Plan de données	Chemin qui ingère, indexe, recherche et transmet du contenu client.
Entitlement	Droit commercial ou capacité activée par l'offre du tenant, distinct d'une permission utilisateur.

3. État actuel et architecture cible

3.1 Inventaire observé dans le dépôt

La baseline technique observée le 22 juillet 2026 est un backend ASP.NET Core ciblant .NET 10, composé de deux projets. Elle constitue une preuve de fonctionnement de l'identité et du contexte utilisateur, mais pas encore une Clean Architecture complète.

Élément	État	Observation	Traitement cible
API ASP.NET Core	EXISTANT	Controllers, Swagger, middleware d'exception et dispatcher interne.	Conserver, compléter avec conventions API, Problem Details, versionnement et politiques.
Authentification Entra	EXISTANT	JWT Bearer via Microsoft.Identity.Web, autorité multi-organisation.	Durcir validation tenant/issuer/audience et ajouter registre de tenants admis.
Contexte d'identité	EXISTANT	Lecture des claims tenant, objet utilisateur, nom et courriel.	Normaliser via une identité externe indépendante de l'IdP.
Organisation et membre	EXISTANT	Deux entités, statut, IdP, identifiants externes et rôle.	Séparer les connexions IdP de l'organisation et permettre plusieurs identités par membre.
RBAC	PARTIEL	Trois rôles et une matrice en mémoire retournée par le bootstrap.	Politiques exécutoires, vérification côté backend, tests et audit des changements.
Persistance	EXISTANT	EF Core SQL Server et scripts Flyway initiaux.	Repositories/use cases, migrations immuables après production, outbox et conventions tenant.
Bootstrap	EXISTANT	GET /api/core/authenticateUser retourne utilisateur, organisation, rôles et permissions.	Renommer/versionner à terme, ajouter provisionnement contrôlé et métadonnées UI.
Connecteurs, ingestion, recherche et IA	ABSENT	Aucun composant observé.	Construire dans l'ordre défini par la roadmap.
Tests, observabilité et CI/CD	NON OBSERVÉ	Aucun projet de test ou pipeline visible dans le périmètre analysé.	Introduire avant d'étendre les fonctionnalités critiques.

DETTE ARCHITECTURALE À TRAITER TÔT

Le projet nommé Repository contient actuellement entités métier, EF Core, requêtes et exceptions applicatives. Avant l'ingestion, réorganiser progressivement en projets Domain, Application, Infrastructure et API. Une migration ciblée est préférable à une réécriture massive.

3.2 Analyse des écarts

Écart	Risque	Priorité	Condition de fermeture
Un seul IdP directement porté par Organization	Impossible de gérer plusieurs connexions ou une migration d'IdP proprement.	P0	Entités OrganizationIdentityProvider et ExternalIdentity introduites.
Absence de JIT contrôlé	Provisionnement manuel ou rejet de tous les nouveaux employés.	P0	Politique d'admission, bootstrap idempotent et premier admin sécurisé.
Permissions seulement informatives	Le frontend pourrait masquer des boutons sans que l'API soit protégée.	P0	Chaque use case sensible exige une policy backend testée.
Aucune convention TenantId généralisée	Fuite inter-tenant lors de l'ajout de tables.	P0	Convention de modèle, contexte obligatoire et suite de tests d'isolation.
Pas d'audit ni d'observabilité structurée	Incidents impossibles à reconstruire.	P0	Événements d'audit, logs corrélés, traces et alertes opérationnels.
Pas de pipeline asynchrone	Synchronisations longues dans les requêtes HTTP et reprises fragiles.	P1	File, outbox, workers idempotents et dead-letter queue.
Aucun modèle de contenu/ACL	Impossible de garantir une recherche sécurisée.	P1	Document, version, chunk, principal, ACL et index définis puis testés.
Aucune mesure de qualité RAG	Réponses plausibles mais non fiables.	P1	Jeu d'évaluation, métriques de récupération, citations et abstention.

4. Architecture globale

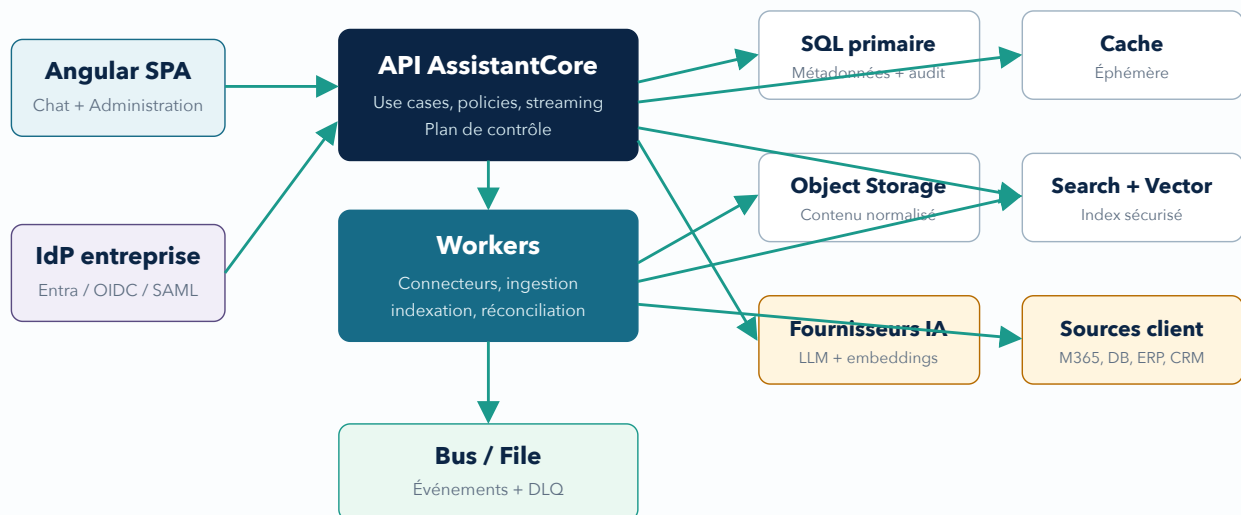
4.1 Style recommandé

DÉCISION ADR-001

Démarrer avec un monolithe modulaire pour le plan de contrôle et l'API interactive, accompagné d'un ou plusieurs processus workers pour les traitements asynchrones. Les frontières de modules sont explicites et les échanges asynchrones passent par des événements. Extraire un microservice uniquement lorsqu'une contrainte mesurée de scalabilité, d'isolation ou de cadence de déploiement le justifie.

Cette approche limite le coût opérationnel d'un produit encore en découverte tout en évitant un monolithe couplé. Les connecteurs et l'ingestion ont des profils de charge différents de l'API ; ils sont donc exécutés dans des workers séparément scalables dès le MVP. Le contrat d'événement et l'outbox rendent une extraction future possible.

VUE DE CONTEXTE ET COMPOSANTS D'EXÉCUTION

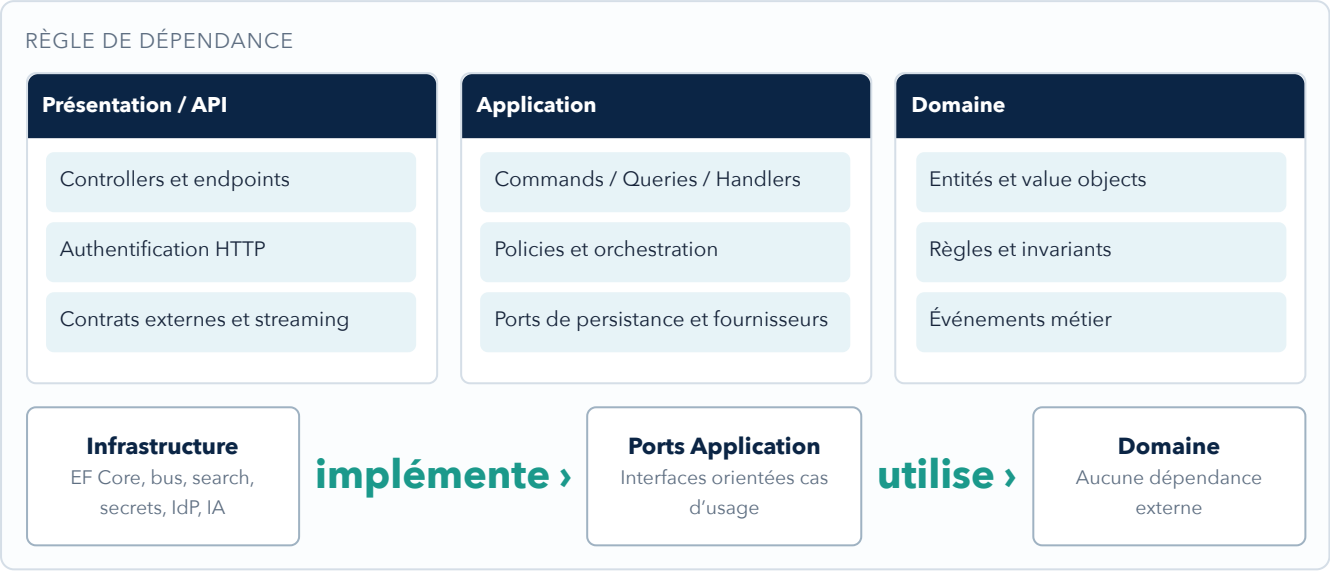


Responsabilités des plans

Plan	Responsabilités	Exclusions
Contrôle	Tenants, identités, rôles, configurations, licences, connecteurs, jobs, audit, politiques.	Ne traite pas directement des volumes documentaires dans les requêtes administratives.
Données	Extraction, normalisation, stockage, ACL, indexation, recherche, construction du contexte.	Ne décide pas des entilements commerciaux.
IA	Routage modèle, prompts versionnés, génération, citations, évaluation et coûts.	N'accorde aucun accès aux sources.

Plan	Responsabilités	Exclusions
Exploitation	Télémétrie, alertes, support, sauvegardes, reprise et gestion d'incident.	Ne donne pas un accès permanent au contenu client.

4.2 Clean Architecture et dépendances



Les handlers orchestrent uniquement un flux simple : validation contextuelle, appel d'une policy ou d'un service métier, persistance et publication d'événements. Les règles de décision complexes vivent dans le domaine ou dans une policy testable. Les contrôleurs traduisent HTTP vers une commande ou requête et ne contiennent pas de logique métier.

Modules fonctionnels internes

Module	Propriétaire des données	Dépendances autorisées
Tenancy	Organization, TenantSettings, TenantStatus	Foundation uniquement.
Identity & Access	IdentityProviderConnection, Member, ExternalIdentity, RoleAssignment, Invitation	Tenancy, Audit.
Entitlements	Plan, Subscription, Entitlement, UsageCounter	Tenancy, Audit.
Connectors	DataSource, ConnectorInstance, CredentialReference, SyncSchedule	Tenancy, Entitlements, Jobs, Audit.
Knowledge	Sourceltem, Document, DocumentVersion, Chunk, ACL, Principal	Connectors, Jobs, Storage.
Search	SearchProfile, QueryLog technique, index projections	Knowledge, Identity & Access.
AI	ModelProfile, PromptTemplate, EvaluationRun, GenerationUsage	Search, Entitlements, Audit.
Conversations	Conversation, Message, Citation, Favorite, ShareGrant	AI, Identity & Access, Retention.
Audit & Operations	AuditEvent, JobRun, IncidentMarker	Transverse, sans dépendance vers le contenu métier.

4.3 Composants d'exécution et technologies

Capacité	Recommandation	Raison	Abstraction exigée
API	ASP.NET Core / .NET 10	Aligné avec l'existant et adapté au streaming et à l'écosystème Microsoft.	Contrats Application sans dépendance HTTP.
Base primaire	SQL Server au démarrage	Déjà en place, transactions fiables, équipe familière.	Repositories ciblés ; pas de fuite EF dans Domain.
File de messages	Service managé compatible topics, retries et DLQ	Découple synchronisation et ingestion, permet la reprise.	MessageBus et conventions d'enveloppe.
Cache	Redis compatible	Idempotence courte, quotas, locks distribués et caches de contexte.	CacheStore avec TTL obligatoire.
Stockage objet	Blob/S3 compatible chiffré	Contenu normalisé et artefacts volumineux hors SQL.	ObjectStorage avec préfixe tenant.
Recherche	Moteur gérant lexical, vectoriel et filtres	Recherche hybride et filtrage ACL dans une même requête.	SearchIndex, SearchQuery, IndexSchemaVersion.
Secrets	Coffre de secrets managé	Rotation, audit et identités managées.	SecretReference ; aucune valeur secrète dans SQL.
Télémétrie	OpenTelemetry	Portabilité des traces, métriques et logs corrélés.	Noms et attributs internes stables.
Feature flags	Service centralisé avec ciblage par environnement et tenant	Déploiements progressifs et désactivation d'urgence.	FeatureManager, valeur par défaut sûre.

4.4 Modèle de données cible

Le modèle logique suivant est normatif ; les noms physiques peuvent évoluer via décision d'architecture. Les identifiants internes sont immuables et ne doivent pas être dérivés d'un identifiant fournisseur.

Agrégat / table logique	Champs structurants	Contraintes clés	Conservation
Organization	Id, Name, Slug, Status, Region, CreatedAt	Slug unique global ; transitions de statut contrôlées.	Contrat + période légale.
OrganizationIdentityProvider	OrganizationId, Type, Issuer, ExternalTenantId, ConfigReference, Status	Issuer + ExternalTenantId unique par connexion ; plusieurs connexions possibles.	Durée de vie tenant.
OrganizationMember	OrganizationId, DisplayName, PrimaryEmail, Status, LastLoginAt	Email normalisé unique si utilisé comme clé d'admission, jamais comme identité immuable.	Politique RH/tenant.
ExternalIdentity	MemberId, ProviderConnectionId, SubjectId, ClaimsSnapshotHash	ProviderConnectionId + SubjectId unique.	Durée de vie membre.
RoleAssignment	MemberId, Role, Scope, GrantedBy, ExpiresAt	Au moins un TenantAdmin actif ; élévations auditées.	Historique en audit.

Agrégat / table logique	Champs structurants	Contraintes clés	Conservation
Invitation / AdmissionPolicy	Email/Domain/Group, Role initial, Expiry, Uses, Status	Jeton haché ; expiration obligatoire ; rôle initial plafonné.	Expiration + fenêtre d'audit.
ConnectorInstance	OrganizationId, Type, Name, CredentialReference, Scope, Schedule, Status	Secret externe ; état explicite ; suppression en deux phases.	Durée de vie tenant.
SyncCursor / JobRun	ConnectorId, Partition, Cursor, Lease, Attempt, Status, ErrorCode	Checkpoint transactionnel et idempotence.	90 jours par défaut.
Document	OrganizationId, ConnectorId, SourceId, URI, Type, CurrentVersionId, Status	OrganizationId + ConnectorId + SourceId unique.	Selon source et politique tenant.
DocumentVersion	DocumentId, SourceVersion, ContentHash, MetadataHash, AclHash, IndexedAt	Version immuable ; une version courante.	Courante + versions configurées.
Chunk	VersionId, Ordinal, TextReference, TokenCount, EmbeddingVersion	Position stable et rattachement obligatoire.	Suit la version.
Principal / DocumentAcl	Provider, ExternalPrincipalId, Type, Allow/Deny, Inheritance	Identité canonique ; deny explicite prioritaire si source le supporte.	Suit le document.
Conversation / Message	OrganizationId, OwnerMemberId, Visibility, Content, Model, CreatedAt	Tenant et propriétaire obligatoires ; suppression logique puis purge.	Tenant configurable.
Citation	MessageId, DocumentVersionId, ChunkId, DisplayLabel, Locator	Référence immuable à la preuve utilisée au moment de répondre.	Suit le message, avec redaction si source supprimée.
AuditEvent	OrganizationId, Actor, Action, Resource, Outcome, CorrelationId, Metadata	Append-only ; horodatage UTC ; données sensibles minimisées.	12 à 24 mois selon offre/politique.
UsageLedger	OrganizationId, Metric, Quantity, Period, IdempotencyKey	Écriture immuable et dédoublonnée.	Finance + contrat.

CONVENTION TEMPORELLE

Tous les horodatages persistés sont en UTC avec précision documentée. Le fuseau du tenant est une préférence d'affichage et de planification, jamais une base de comparaison métier.

5. Architecture multi-tenant

5.1 Résolution et isolation

DÉCISION ADR-002

Utiliser au démarrage un modèle partagé : calcul partagé, base partagée et schéma partagé, avec OrganizationId obligatoire sur toutes les données client. Prévoir une stratégie « deployment stamp » et une option de ressources dédiées pour les grands comptes, sans l'implémenter avant besoin commercial.

Le tenant est résolu à partir de la connexion IdP reconnue et des claims validés. Le tenant transmis dans une URL, un header ou un body n'est jamais une preuve d'autorité. Une fois résolu, un TenantContext immuable est créé pour la requête et propagé aux use cases, logs, traces, repositories, messages et compteurs.

Défenses obligatoires

Niveau	Contrôle	Échec attendu
Jeton	Signature, issuer, audience, expiration, type de sujet et tenant externe validés.	401 sans résolution de ressource.
Admission	Connexion IdP active et tenant actif dans le registre SaaS.	403 générique, audit de refus.
Application	TenantContext obligatoire pour toute opération tenant-scoped.	Erreur technique fermée si contexte absent.
Persistence	Chaque requête et commande inclut OrganizationId ; clés uniques composées.	Aucun résultat plutôt qu'un fallback global.
Recherche	Filtre tenant non modifiable ajouté côté serveur, puis ACL.	Zéro hit si principal non résolu.
Stockage objet	Préfixe/conteneur tenant, identité worker limitée et chiffrement.	Accès refusé hors partition.
Cache	Clés préfixées par environnement, tenant et version.	Pas de clé globale pour contenu utilisateur.
Messages	Enveloppe avec OrganizationId, CorrelationId, SchemaVersion et IdempotencyKey.	Message invalide placé en quarantaine.

ANTI-PATTERN INTERDIT

Une requête générique suivie d'un filtrage tenant en mémoire est interdite. Le prédicat tenant doit être appliqué par le système de stockage ou le moteur de recherche avant le retour des données.

Tests d'isolation obligatoires

- Chaque repository tenant-scoped est testé avec des enregistrements identiques dans deux tenants.
- Chaque endpoint d'administration rejette un identifiant appartenant à un autre tenant sans révéler son existence.

- Chaque requête search combine tenant et ACL dans le filtre exécuté par le moteur.
- Les caches, fichiers, événements et exports sont vérifiés avec des clés de tenant distinctes.
- Les tâches de support utilisent une élévation temporaire, motivée, approuvée et auditée.

5.2 Cycle de vie d'un tenant

État	Entrées autorisées	Comportement	Sorties
Provisioning	Création commerciale ou administrative validée.	Réserve l'organisation, région, offre et premier mécanisme d'identité.	Active après consentement et bootstrap du premier admin.
Active	Configuration valide, subscription autorisant l'usage.	Connexion, synchronisation, recherche et administration disponibles.	Suspended, Offboarding.
Suspended	Incident, impayé, décision client ou sécurité.	Accès interactif refusé ; synchronisations arrêtées ; données conservées.	Active après résolution, ou Offboarding.
Offboarding	Résiliation confirmée.	Accès fermé, export possible selon contrat, jobs annulés, délai de grâce.	Purging.
Purging	Délai de grâce expiré et hold juridique absent.	Purge orchestrée des bases, index, objets, caches et secrets ; sauvegardes expirent selon cycle.	Deleted.
Deleted	Rapport de purge complet.	Seules les preuves minimales autorisées sont conservées.	Aucune réactivation ; nouveau tenant requis.

Critères d'acceptation – Multi-tenant

- Aucun use case tenant-scoped ne s'exécute sans TenantContext validé.
- Une suite automatique démontre l'absence de lecture, écriture, recherche et cache croisés.
- La suspension prend effet sur l'API et les workers dans le délai défini, sans dépendre du frontend.
- La purge produit un rapport corrélé listant tous les systèmes traités.

6. Identité et authentification

6.1 Microsoft Entra ID – fournisseur initial

L'application Entra est multi-tenant et réservée aux comptes professionnels. Le frontend Angular utilise Authorization Code avec PKCE via une bibliothèque supportée. Il demande un access token destiné à l'API AssistantCore ; l'API valide ce jeton et n'accepte pas un token destiné à Microsoft Graph.

Contrôle	Exigence	Remarque
Signature et algorithme	Validation via métadonnées OIDC et clés publiées, avec gestion du rollover.	Ne jamais implémenter manuellement la cryptographie.
Audience	Doit correspondre à l'API AssistantCore.	Évite le « confused deputy » avec un token Graph.
Issuer et tenant	Issuer cohérent avec le tenant du claim et tenant présent dans le registre.	Une autorité organizations n'autorise pas automatiquement tous les tenants.
Sujet	Identifiant objet/subject non vide et type utilisateur attendu.	Ne pas autoriser un service principal comme membre humain par simple présence d'un identifiant.
Temps	Expiration et not-before validés avec faible tolérance d'horloge.	Horloges des nœuds synchronisées.
Assurance	Le client peut exiger MFA/Conditional Access ; le SaaS documente les claims nécessaires si une action exige une authentification renforcée.	Ne pas déduire MFA d'un champ non contractuel.

Consentement et accès à Microsoft Graph

La connexion utilisateur au SaaS et le consentement d'un connecteur sont deux opérations distinctes. Le SSO nécessite seulement les scopes de l'API et de profil indispensables. Le connecteur Graph utilise une autorisation administrateur séparée, de préférence applicative avec permissions limitées au périmètre sélectionné lorsque Microsoft le permet. Les credentials de connecteur ne sont jamais retournés au navigateur.

6.2 Abstraction multi-IdP

DÉCISION ADR-003

Le domaine ne dépend d'aucun claim Microsoft. Une couche d'adaptation transforme chaque identité validée en ExternalIdentityDescriptor contenant ProviderType, Issuer, ExternalTenantId, SubjectId, DisplayName, Email et claims normalisés. La liaison au membre est persistée séparément.

Fournisseur / protocole	Stratégie	Identifiant stable	Points d'attention
Microsoft Entra ID	Validation directe OIDC/OAuth 2.0.	Connexion tenant + oid/sub.	Invités, cloud souverain, groupes en overage, consentement admin.
Auth0 / Okta / Ping / Keycloak	Adaptateur OIDC générique lorsque possible.	Issuer + subject.	Découverte, rotation JWKS, mapping claims, domaines multiples.
SiteMinder / SAML 2.0	Passer par un broker d'identité ou une gateway spécialisée, puis émettre un token interne OIDC.	EntityId + NameID stable défini contractuellement.	Signature, chiffrement assertion, replay, clock skew, metadata rotation.
Active Directory on-prem	Fédération via Entra, ADFS ou broker ; pas de validation LDAP directe par l'API SaaS.	Issuer fédéré + subject immuable.	Connectivité, cycle de vie, comptes désactivés et groupes.
IdP futur	Doit passer la suite de conformité IdentityProviderAdapter.	Issuer + subject, tenant externe si fourni.	Refus par défaut si claims minimaux absents.

Contrat minimal d'un adaptateur

- Valider le jeton/assertion en utilisant une bibliothèque maintenue et une configuration propre à la connexion.
- Produire une identité normalisée sans accorder de rôle produit.
- Résoudre la connexion IdP et le tenant à partir de valeurs validées.
- Normaliser les identifiants de groupes ou signaler qu'une résolution externe est nécessaire.
- Exposer des codes d'erreur stables et de la télémétrie sans token ni PII excessive.
- Supporter la rotation des clés et métadonnées sans redéploiement.

Migration d'un IdP

Une organisation peut activer une deuxième connexion en mode transition. Les membres lient leur nouvelle identité via un flux administré ou une preuve sur les deux IdP. La correspondance automatique par courriel seul est interdite pour les rôles privilégiés. L'ancien IdP est ensuite passé en lecture seule, désactivé, puis supprimé après vérification qu'au moins un TenantAdmin peut encore se connecter.

6.3 Bootstrap, invitations et provisionnement JIT

DÉCISION PRODUIT ET SÉCURITÉ

Un membre peut être créé automatiquement à sa première connexion, mais uniquement si l'organisation existe et si une politique d'admission l'autorise. Le JIT ouvert à tout utilisateur d'un tenant est désactivé par défaut.

Politique d'admission	Usage recommandé	Rôle initial maximal	Vérification
Invitation nominative	MVP et organisations contrôlées.	User ou Manager selon l'émetteur.	Email normalisé + identité IdP ; jeton à usage limité.

Politique d'admission	Usage recommandé	Rôle initial maximal	Vérification
Domaines vérifiés	Déploiement large dans une entreprise.	User.	Domaine administrativement vérifié, sans accepter un domaine public.
Groupe IdP autorisés	Administration centralisée côté client.	User ou mapping approuvé.	Résolution de groupes complète, y compris overage.
SCIM	Cycle de vie entreprise mature.	Selon mapping contrôlé.	Provisionnement avant connexion, désactivation rapide.
JIT tenant-wide	Exception explicitement acceptée par le TenantAdmin.	User uniquement.	Tenant connu, utilisateur humain, audit et quota.

Flux de première connexion



1. Valider le jeton avant toute requête métier.
2. Résoudre exactement une connexion IdP active et un tenant actif.
3. Rechercher ExternalIdentity par connexion et SubjectId, jamais globalement par courriel.
4. Si elle existe, vérifier membre, rôle et suspension ; mettre à jour les attributs d'affichage non sensibles selon la politique.
5. Sinon, évaluer les politiques d'admission dans un ordre déterministe.
6. Créer membre, identité et rôle initial dans une transaction unique avec clé d'idempotence.
7. Émettre l'audit MemberProvisioned et retourner le contexte.

PREMIER ADMINISTRATEUR

Le premier TenantAdmin est créé par un flux d'onboarding séparé : contrat ou commande valide, consentement administrateur vérifié et preuve de contrôle du tenant IdP. Le premier utilisateur qui se présente ne devient jamais automatiquement administrateur.

6.4 Current User et contexte utilisateur

Le endpoint actuel `GET /api/core/authenticateUser` sert de bootstrap frontend après le SSO. Pour clarifier sa sémantique, la cible est `GET /api/v1/me/context`. Une période de compatibilité peut conserver l'ancien chemin. Ce endpoint ne « connecte » pas l'utilisateur : il transforme une identité déjà authentifiée en contexte applicatif.

Réponse fonctionnelle cible

Bloc	Données	Raison
User	Identifiant interne, nom d'affichage, courriel, préférences, statut.	Initialiser l'expérience et la personnalisation.
Organization	Identifiant, nom, branding minimal, locale, fuseau.	Contexte visuel et régional.

Bloc	Données	Raison
Authorization	Rôles et permissions effectives.	Adapter l'interface ; le backend les revérifie toujours.
Entitlements	Fonctionnalités de l'offre, limites pertinentes, état d'abonnement.	Masquer ou expliquer une capacité indisponible.
Features	Flags exposables au client.	Rollouts progressifs ; aucun secret de configuration.
Onboarding	Étapes requises, état des sources, disponibilité du chat.	Guider admin ou utilisateur.
Correlation	RequestId et version du contrat.	Support et compatibilité.

Comportements d'erreur

Situation	HTTP	Code stable	Comportement UI
Jeton absent/invalidé	401	AUTHENTICATION_REQUIRED	Renouveler le token puis rediriger vers SSO si nécessaire.
Tenant inconnu ou non admis	403	TENANT_ACCESS_DENIED	Écran d'accès non configuré, sans détail sensible.
Membre suspendu	403	MEMBER_SUSPENDED	Message support organisation.
Invitation requise	403	ADMISSION_REQUIRED	Demande d'accès si activée.
Tenant suspendu	403	TENANT_SUSPENDED	Message administrateur/facturation selon contexte.
Erreur temporaire	503	IDENTITY_CONTEXT_UNAVAILABLE	Réessai borné, afficher RequestId.

Critères d'acceptation – Identité

- Un utilisateur d'un tenant non enregistré reçoit un refus identique, quel que soit son rôle Entra.
- Deux connexions simultanées du même nouvel utilisateur créent un seul membre.
- La désactivation d'un membre est effective à la requête suivante et invalide les caches d'autorisation.
- La migration d'IdP ne modifie pas l'identifiant interne ni les conversations du membre.
- Aucun token, secret ou assertion n'apparaît dans les logs et audits.

7. Autorisation, rôles et ACL

7.1 RBAC produit

Le RBAC régit ce qu'un utilisateur peut faire dans AssistantCore. Il ne lui donne aucun droit supplémentaire sur les documents connectés. Les permissions sont des constantes applicatives stables ; les rôles sont des regroupements. Les entilements du plan commercial constituent un troisième axe indépendant.

Permission	TenantAdmin	Manager	User	Notes
Organization.Read	Oui	Oui	Oui	Informations non sensibles du tenant.
Organization.Manage	Oui	Non	Non	Paramètres généraux et politiques.
Members.Read	Oui	Oui	Non	Liste minimisée.
Members.Manage	Oui	Non	Non	Inviter, suspendre, modifier rôle avec garde-fous.
Connectors.Read	Oui	Oui	Non	Le Manager ne voit jamais les secrets.
Connectors.Manage	Oui	Non	Non	Consentement, périmètre, synchronisation.
Audit.Read	Oui	Option	Non	Manager selon politique tenant.
Search.Use	Oui	Oui	Oui	Sous réserve de licence et de source disponible.
Conversations.Share	Oui	Oui	Oui	Si le tenant autorise le partage.
Billing.Manage	Option	Non	Non	Idéalement rôle BillingAdmin distinct à terme.
Data.Export	Oui	Non	Export personnel	Export tenant renforcé et audité.

Règles de rôles

- Une organisation active possède toujours au moins un TenantAdmin actif.
- Un administrateur ne peut pas retirer son propre dernier rôle TenantAdmin.
- Une élévation de rôle exige réauthentification récente si la politique le demande.
- Les rôles du SaaS ne sont pas dérivés de façon implicite d'un titre, d'un email ou d'un rôle source.
- Les rôles personnalisés sont différés ; le schéma RoleAssignment les rend possibles sans casser l'API.
- Chaque modification enregistre acteur, ancien état, nouvel état, justification éventuelle et corrélation.

7.2 ACL des sources

Les ACL déterminent quels documents peuvent être récupérés pour l'utilisateur. Elles proviennent de la source, sont normalisées à l'ingestion et appliquées comme filtre obligatoire au moment de la requête. Le système construit un PrincipalSet à partir de l'identité externe, des groupes synchronisés et des pseudo-principaux autorisés.

Permission produit

Search.Use autorise la fonction

**Entitlement**

Le plan autorise la recherche

**ACL source**

Le principal peut lire le document

**Résultat autorisé**

Sinon refus ou document absent

Modèle de principal

Type	Clé canonique	Résolution	Usage
User	ProviderConnectionId + ExternalUserId	Depuis l'identité authentifiée.	Partage direct.
Group	ProviderConnectionId + ExternalGroupId	Claims si complets, sinon annuaire/cache contrôlé.	ACL d'équipe, site, bibliothèque.
EveryoneInTenant	Pseudo-principal interne + OrganizationId	Créé uniquement à partir d'une sémantique source vérifiée.	Contenu interne général.
Anonymous / public link	Non converti automatiquement en accès SaaS.	Politique explicite du tenant.	Désactivé par défaut.
Application	ProviderConnectionId + ApplId	Contexte machine séparé.	Jobs ; jamais assimilé à un humain.

Règles ACL

- La sémantique d'héritage de la source est matérialisée ou résolue de façon déterministe.
- Un deny explicite prime sur un allow lorsqu'il existe dans le modèle source.
- Une ACL inconnue, tronquée ou en erreur rend le document non recherchable.
- Le changement d'ACL déclenche une mise à jour prioritaire, même si le contenu n'a pas changé.
- Le moteur de recherche reçoit les filtres tenant et PrincipalSet dans la requête, avant ranking.
- Le cache d'appartenance aux groupes a un TTL court et une invalidation événementielle lorsque possible.
- Les citations réévaluent l'accès lors de l'ouverture ; une ancienne conversation ne contourne pas une révocation.

FENÊTRE DE COHÉRENCE

Le contrat de service doit définir le délai maximal de propagation d'une révocation. Pour le pilote : objectif de 5 minutes pour un changement détecté par webhook/delta et réconciliation complète quotidienne. Les documents dont l'ACL ne peut plus être confirmée sont mis en quarantaine.

7.3 Politiques d'autorisation

Les endpoints déclarent une permission, mais la décision finale est prise au niveau Application par une policy qui combine membre actif, tenant actif, permission, entitlement, scope de ressource et éventuelles règles métier. Le controller ne lit pas directement le rôle.

Policy	Entrées	Décision	Audit
CanManageMembers	Acteur, tenant, membre cible, modification demandée.	Members.Manage, même tenant, garde-fou dernier admin, niveau suffisant.	Toujours pour modification.
CanManageConnector	Acteur, connector, entitlement.	Connectors.Manage, même tenant, type autorisé par plan.	Création, secret, périmètre, suppression.
CanSearch	Acteur, tenant, état services.	Search.Use, entitlement, quota, tenant actif.	Usage agrégé ; détail selon politique.
CanReadDocument	Tenant, PrincipalSet, ACL document.	Tenant égal et ACL satisfaite.	Trace technique corrélée, pas nécessairement événement métier individuel.
CanReadConversation	Acteur, conversation, share grant.	Propriétaire ou partage valide, même tenant.	Partage et accès sensibles.
CanExportTenantData	Acteur, assurance auth, tenant.	Permission export, réauth récente, approbation éventuelle.	Obligatoire, avec périmètre et destination.

Critères d'acceptation – Autorisation

- Masquer une fonction dans Angular n'est jamais le seul contrôle.
- Toutes les politiques ont des tests allow et deny, dont un scénario inter-tenant.
- Un retrait de groupe empêche l'ouverture d'une citation après propagation.
- Un document à ACL invalide n'est ni indexé ni envoyé au LLM.
- Les rôles et entitlements peuvent évoluer sans réindexer les documents ; les ACL peuvent évoluer sans régénérer le contenu.

8. Administration du tenant

8.1 Organisations et paramètres

La console d'administration est une zone du frontend Angular protégée par permissions. Elle n'est pas nécessaire à l'usage quotidien d'un employé, mais elle est indispensable pour rendre le SaaS autonome après onboarding. Toute configuration sensible est validée côté backend et auditée.

Paramètres fonctionnels

Catégorie	Paramètres	Valeur par défaut	Validation
Profil	Nom, logo, langue, fuseau, contacts techniques et sécurité.	Définis à l'onboarding.	Formats, taille image, emails valides.
Admission	Invitations, domaines vérifiés, groupes autorisés, JIT.	Invitation uniquement.	Un admin ne peut pas ouvrir l'accès sans confirmation explicite.
Conversations	Historique, partage, durée de conservation, export.	Historique privé, partage interne désactivé au pilote.	Respect des minima/maxima contractuels.
IA	Modèles autorisés, langues, mode citation, conservation fournisseur, régions.	Profil sécurisé de la plateforme.	Compatible avec offre et région du tenant.
Sources	Types autorisés, taille, extensions, fréquence maximale, contenu exclu.	Allowlist documentée.	Vérification au connecteur et à l'ingestion.
Sécurité	Session, réauthentification, IP allowlist future, export, support access.	Profil standard strict.	Une réduction de sécurité affiche l'impact et exige confirmation.
Notifications	Destinataires et seuils pour erreurs, quotas et incidents.	TenantAdmins actifs.	Canaux vérifiés et anti-spam.

Règles métier

- Les paramètres sont versionnés et mis à jour avec contrôle de concurrence optimiste.
- Les paramètres absents héritent d'une baseline plateforme sécurisée et versionnée.
- Une modification qui nécessite réindexation affiche son impact, crée un job et ne bloque pas la requête HTTP.
- Une baisse de rétention ne supprime pas silencieusement : elle planifie une purge et génère un audit.
- Les paramètres qui ne concernent qu'un fournisseur restent dans sa configuration, pas dans l'agrégat Organization.

8.2 Membres, invitations, rôles et accès

Le modèle recommandé combine provisionnement automatique contrôlé et administration. L'administrateur ne saisit donc pas nécessairement chaque employé. Il configure les règles d'admission, suit les membres provisionnés et gère les exceptions : promotion, suspension, retrait ou invitation ciblée.

Fonction	Comportement attendu	Règles essentielles
Liste des membres	Recherche, filtre statut/rôle/source d'admission, pagination, dernière connexion.	PII minimisée ; tri stable ; pas d'exposition d'identifiants externes inutiles.
Invitation	Invitation nominative avec rôle initial, expiration et message optionnel.	Jeton haché, usage unique ou borné, révocable, rôle plafonné.
JIT	Création automatique lors d'une connexion conforme à une policy.	Transaction idempotente, User par défaut, quota vérifié.
Changement de rôle	Effet immédiat sur les appels suivants.	Dernier admin protégé, élévation audité, cache invalidé.
Suspension	Bloque l'API et le partage sans supprimer l'historique.	Raison, acteur et date ; sessions/tokens applicatifs révoqués si disponibles.
Suppression	Désactive puis purge/anonymise selon politique.	Ne supprime pas les audits obligatoires ; traite conversations et partages.
Synchronisation annuaire	SCIM ou groupes IdP à terme.	La source de vérité et le comportement de désactivation sont explicites.
Export	Export CSV administratif ou export personnel.	Autorisation, chiffrement, expiration du lien et audit.

États d'un membre

État	Connexion	Recherche	Administration	Transition
Invited	Peut accepter si invitation valide.	Non.	Visible et révocable.	Active ou Expired.
Active	Oui.	Selon rôle, entitlement et ACL.	Selon permissions.	Suspended ou Deprovisioning.
Suspended	Refusée.	Non.	Restaurable par admin autorisé.	Active ou Deprovisioning.
Deprovisioning	Refusée.	Non.	Purge en cours, restauration bornée selon politique.	Deleted.
Deleted	Refusée.	Non.	Référence minimale/anonymisée.	Nouveau membre si réadmission.

8.3 Licences, entitlements et facturation

La facturation peut être différée, mais son modèle doit être prévu avant que les quotas ne se dispersent dans le code. Le produit distingue l'offre commerciale, la subscription d'un tenant, les entitlements activés et le ledger d'usage mesuré.

DÉCISION ADR-004

Les use cases interrogent un EntitlementService et un QuotaService, jamais un nom de plan comme « Pro » ou « Enterprise ». Cela permet de modifier le catalogue commercial sans réécrire les règles métier.

Objet	Rôle	Exemples
Plan	Modèle commercial versionné.	Pilot, Business, Enterprise.
Subscription	Association d'un tenant à un plan et à une période.	Trial, Active, PastDue, Suspended, Cancelled.
Entitlement	Capacité booléenne ou limite.	Connecteur SQL, partage, nombre de sources, stockage, requêtes mensuelles.
UsageLedger	Événements de consommation idempotents.	Tokens, embeddings, documents, stockage, recherches.
Meter aggregate	Agrégat de période utilisé pour quota et facture.	Usage journalier/mensuel par tenant.
Invoice reference	Lien vers le fournisseur de facturation.	Identifiant externe, état, montant, devise.

Comportements de quota

- Les limites dures bloquent avant l'opération coûteuse et retournent une erreur explicite avec possibilité d'action.
- Les limites souples déclenchent des alertes à 80 %, 95 % et 100 %, sans promettre un blocage exact au token près.
- Les écritures de ledger utilisent une clé d'idempotence pour ne pas doubler la facturation lors d'un retry.
- Une panne du fournisseur de facturation ne bloque pas le chemin RAG ; le ledger local fait autorité temporaire.
- Les remises, crédits et ajustements sont des écritures explicites et auditable, jamais une modification rétroactive silencieuse.

Critères d'acceptation – Administration

- Un TenantAdmin peut rendre un tenant utilisable sans intervention en base de données.
- Un utilisateur admis par policy est provisionné sans saisie manuelle.
- Les changements de rôle, statut, paramètres et connecteurs sont auditable.
- Les endpoints administratifs ne renvoient jamais une valeur de secret.
- Un entitlement retiré désactive la capacité sans supprimer automatiquement les données.

9. Contrat API et comportements transverses

9.1 Catalogue des endpoints

Les chemins ci-dessous définissent le contrat cible v1. Les listes utilisent une pagination par curseur lorsque le volume peut changer pendant la lecture. Les opérations créant un job retournent 202 et une ressource de suivi. Les endpoints de plateforme sont exposés sur une surface séparée et ne sont pas accessibles aux rôles tenant.

Identité et contexte

Méthode et route	Permission	Usage	Résultat
GET /api/v1/me/context	Authentifié + admission	Appelé après SSO et au rechargement de l'application.	Utilisateur, tenant, permissions, entitlements, features et onboarding.
GET /api/v1/me/preferences	Authentifié	Lire les préférences personnelles.	Locale, thème, options conversationnelles non sensibles.
PATCH /api/v1/me/preferences	Authentifié	Modifier les préférences autorisées.	Préférences et version mises à jour.
DELETE /api/v1/me	Authentifié + policy	Demander suppression/anonymisation personnelle.	202 et identifiant de demande.

Organisation et membres

Méthode et route	Permission	Usage	Règles
GET /api/v1/organization	Organization.Read	Lire le profil courant.	Le tenant vient du contexte, pas de la route.
PATCH /api/v1/organization	Organization.Manage	Modifier profil et paramètres simples.	ETag/version obligatoire.
GET /api/v1/members	Members.Read	Lister/rechercher les membres.	Pagination, filtres allowlistés.
GET /api/v1/members/{memberId}	Members.Read	Consulter un membre du tenant.	404 uniforme si autre tenant ou absent.
PATCH /api/v1/members/{memberId}	Members.Manage	Changer rôle ou statut.	Politiques dernier admin et élévation.
POST /api/v1/invitations	Members.Manage	Créer une invitation.	Idempotency-Key ; rôle plafonné.
GET /api/v1/invitations	Members.Read	Suivre les invitations.	Jetons jamais retournés.

Méthode et route	Permission	Usage	Règles
DELETE /api/v1/invitations/{id}	Members.Manage	Révoquer une invitation.	Idempotent.
GET /api/v1/admission-policies	Members.Read	Lire les règles JIT.	Domaines vérifiés clairement identifiés.
PUT /api/v1/admission-policies/{id}	Members.Manage	Créer/modifier une règle.	Confirmation explicite pour JIT ouvert.

Connecteurs et synchronisations

Méthode et route	Permission	Usage	Résultat
GET /api/v1/connector-types	Connectors.Read	Catalogue disponible selon entitlements.	Schéma de configuration public et capacités.
POST /api/v1/connectors	Connectors.Manage	Créer un connecteur en brouillon.	201 sans secret.
POST /api/v1/connectors/{id}/authorize	Connectors.Manage	Démarrer consentement ou produire une session de secret.	URL/étape courte durée, anti-CSRF.
PATCH /api/v1/connectors/{id}	Connectors.Manage	Modifier périmètre et horaire.	Impact de réindexation communiqué.
POST /api/v1/connectors/{id}/test	Connectors.Manage	Tester authentification, réseau et permissions.	Résultat diagnostic sans donnée sensible.
POST /api/v1/connectors/{id}/sync-runs	Connectors.Manage	Déclencher une synchronisation.	202 + JobRun ; dédoublonnage si déjà en cours.
GET /api/v1/connectors/{id}/sync-runs	Connectors.Read	Historique et progression.	Compteurs, curseur masqué, erreurs actionnables.
POST /api/v1/connectors/{id}/pause	Connectors.Manage	Arrêter les nouveaux travaux.	Le job courant atteint un checkpoint sûr.
DELETE /api/v1/connectors/{id}	Connectors.Manage	Désactiver puis purger les projections.	202 + job de purge.

Recherche, réponses et conversations

Méthode et route	Permission	Usage	Résultat
POST /api/v1/search	Search.Use	Recherche explicite sans génération.	Résultats ACL-filtered avec extraits et métadonnées.
POST /api/v1/conversations	Search.Use	Créer une conversation.	201 et conversation privée.
POST /api/v1/conversations/{id}/messages	Search.Use + accès conversation	Poser une question ; réponse en streaming.	SSE ou flux HTTP : statuts, texte, citations, usage.

Méthode et route	Permission	Usage	Résultat
GET /api/v1/conversations	Authentifié	Lister et rechercher l'historique accessible.	Pagination, filtre favoris, texte autorisé.
GET /api/v1/conversations/{id}	Accès conversation	Charger messages et citations.	ACL de conversation et revalidation des liens source.
PATCH /api/v1/conversations/{id}	Propriétaire	Renommer, mettre en favori, archiver.	Concurrence optimiste.
POST /api/v1/conversations/{id}/shares	Conversations.Share	Partager dans le tenant.	Grant explicite, expiration optionnelle.
DELETE /api/v1/conversations/{id}	Propriétaire ou admin selon policy	Supprimer l'historique.	202 si purge asynchrone.
POST /api/v1/messages/{id}/feedback	Accès message	Évaluer réponse/citation.	Un feedback actif par utilisateur et message.

Audit, usage et opérations tenant

Méthode et route	Permission	Usage	Protection
GET /api/v1/audit-events	Audit.Read	Filtrer les événements du tenant.	Pagination, plage maximale, redaction.
POST /api/v1/audit-exports	Audit.Read + export policy	Créer un export chiffré.	202, lien expirant, audit de téléchargement.
GET /api/v1/usage	Organization.Manage	Usage et quotas de période.	Agrégats tenant uniquement.
GET /api/v1/subscription	Organization.Manage	Plan, entilements et état.	Pas de donnée carte bancaire.
GET /api/v1/health/sources	Connectors.Read	Santé fonctionnelle des sources du tenant.	Distinct des probes plateforme anonymes.

9.2 Validation, erreurs et conventions

Convention	Décision
Versionnement	Version majeure dans l'URL. Changements additifs compatibles ; retrait après période de dépréciation documentée.
Erreurs	Problem Details JSON avec type/code stable, titre localisable, statut, RequestId, erreurs de champs ; aucune stack trace en production.
Validation	Syntaxe à la frontière, règles métier dans domaine/policies. Toutes les erreurs client connues sont déterministes.
Idempotence	Idempotency-Key exigée pour créations coûteuses, consentements, sync, exports et opérations de facturation.
Concurrence	ETag ou version sur paramètres, membres, conversations et connecteurs. Conflit retourné en 409.

Convention	Décision
Pagination	Curseur opaque, taille par défaut 25, maximum 100 sauf export. Ordre stable avec identifiant de départage.
Corrélation	RequestId accepté ou généré, propagé aux traces, événements, jobs et appels externes.
Temps	ISO 8601 UTC dans les contrats ; fuseau uniquement pour affichage ou expression de calendrier.
Streaming	SSE recommandé pour la réponse v1 : événements typés, heartbeat, annulation client et message final persistant.
Rate limiting	Par IP avant auth, puis tenant + membre + opération. Réponse 429 avec Retry-After.
Documentation	OpenAPI publié par version ; exemples sans secrets ; permissions et erreurs documentées.

Taxonomie d'erreurs

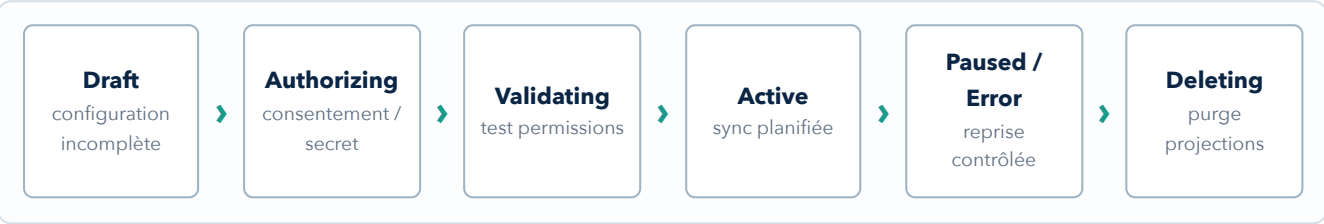
Famille	HTTP usuels	Exemples	Retry
Authentication	401	Token absent, expiré, audience invalide.	Après renouvellement uniquement.
Authorization	403	Permission, entitlement, tenant ou ACL refusé.	Non sans changement de droits.
Validation	400/422	Champ invalide, règle métier non satisfaite.	Après correction.
Not found	404	Absent ou ressource d'un autre tenant.	Non.
Conflict	409	Version obsolète, unicité, job concurrent.	Après relecture/backoff.
Quota	429	Débit ou quota temporaire.	Selon Retry-After.
Dependency	502/503/504	Source, moteur search ou IA indisponible.	Borné, si opération idempotente.
Internal	500	Erreur inattendue.	Pas automatiquement côté client sauf politique.

10. Plateforme de connecteurs

10.1 Contrat commun

Un connecteur convertit une source en flux d'items et d'ACL sans connaître le moteur de recherche ni le LLM. Il est développé contre un SDK interne et doit passer une suite de conformité avant activation. Les capacités optionnelles sont déclarées : incremental sync, webhook, ACL, delete detection, schema discovery, content streaming et health check.

Cycle de vie



Contrat fonctionnel obligatoire

Capacité	Responsabilité du connecteur	Responsabilité plateforme
Authentification	Définir mode, scopes et validation des credentials.	Stocker références de secrets, rotation, identité managée et audit.
Découverte	Énumérer les conteneurs sélectionnables et valider le périmètre.	UI standard et conservation de la sélection.
Synchronisation initiale	Lire par pages avec curseur stable.	Planifier partitions, backpressure, checkpoints et progression.
Incrémental	Utiliser delta, watermark, CDC ou webhook si fiable.	Conserver le curseur uniquement après traitement durable.
Contenu	Fournir stream, type, taille, version et métadonnées source.	Antivirus, extraction, stockage, chunking et quotas.
ACL	Fournir permissions, héritage et principaux avec sémantique documentée.	Normaliser, résoudre, indexer et appliquer.
Suppressions	Émettre tombstones ou participer à la réconciliation.	Désindexer rapidement et purger selon politique.
Erreurs	Classifier auth, throttling, transient, permanent et data.	Retry, DLQ, alertes et runbook.
Santé	Tester reachability, credentials, scopes et curseur.	Dashboard, SLO, notifications et suspension automatique ciblée.

Politique de reprise

- Retry exponentiel avec jitter pour throttling, timeouts et erreurs 5xx ; respecter Retry-After.

- Aucun retry automatique pour secret invalide, permission retirée, scope inexistant ou donnée systématiquement illisible.
- Une unité de travail est idempotente via ConnectorId, SourceItemId et SourceVersion.
- Le curseur n'avance qu'après persistance des événements ou de l'outbox associés à la page.
- Après le nombre maximal d'essais, l'item va en quarantaine sans bloquer toute la partition si la sécurité le permet.
- Un circuit breaker protège la source et les workers ; sa fermeture est progressive.

Fréquences standard

Mode	Usage	Fréquence indicative	Contrainte
Webhook + delta	Sources supportant notification fiable.	Minutes, avec debounce.	Webhook n'est qu'un signal ; delta reste la source de vérité.
Delta planifié	Graph et APIs à curseur.	5 à 30 minutes selon offre.	Throttling et budget par tenant.
Watermark	Bases et APIs avec colonne monotone.	15 minutes à 24 heures.	Gérer égalités et late arrivals.
Snapshot	Source sans incrémental.	Quotidien ou hebdomadaire.	Coût, fenêtre, déduplication et suppression.
Réconciliation	Toutes les sources.	Quotidienne partielle, complète périodique.	Détecter dérives de contenu et ACL.

10.2 Microsoft Graph, SharePoint et OneDrive

Le premier connecteur doit cibler SharePoint Online et OneDrive for Business via Microsoft Graph. Le consentement administrateur, la sélection de sites et la synchronisation de contenu/permissions constituent un même produit mais des étapes séparées.

Aspect	Spécification
Authentification	Application consentie dans le tenant client, credentials par certificat ou identité fédérée lorsque disponible. Éviter les secrets longue durée. Permissions minimales et accès limité aux sites sélectionnés lorsqu'applicable.
Découverte	Lister les sites/bibliothèques accessibles au connecteur ; l'admin sélectionne explicitement le périmètre. La recherche globale de sites n'implique pas leur indexation.
Initiale	Par site, drive et partition ; lecture paginée ; contenu téléchargé en streaming ; versions et métadonnées conservées.
Incrémentale	Delta query par drive ou ressource, deltaLink conservé après traitement durable. Notifications utilisées pour réduire la latence, jamais comme journal complet.
ACL	Permissions directes et héritées, liens de partage et principaux normalisés. Les variations de permissions sont traitées même sans changement de contenu.
Suppressions	Tombstones delta immédiatement désindexés ; réconciliation périodique pour les événements manqués.
Throttling	Respect de Retry-After, budget de concurrence par tenant et app, réduction automatique de cadence.

Aspect	Spécification
Erreurs	Consentement retiré → NeedsReauthorization ; site absent → périmètre invalide ; item interdit → quarantaine sans fuite de nom ; delta expiré → resynchronisation contrôlée.
Monitoring	Âge du dernier delta, taux d'items, octets, erreurs 401/403/429, backlog, documents quarantinés et délai ACL.

Types de contenu MVP

PDF texte, DOCX, PPTX, XLSX avec limites, TXT, HTML et pages modernes supportées par extracteur. Les archives, médias audio/vidéo, images sans OCR et fichiers chiffrés sont ignorés ou mis en quarantaine avec raison explicite. L'OCR et le multimodal sont des évolutions soumises à coût, langue et confidentialité.

PERMISSIONS MICROSOFT

Les permissions Graph exactes doivent être validées pendant l'implémentation selon le mode d'accès retenu et la capacité sélectionnée. Le produit doit afficher clairement à l'administrateur ce qui est demandé, pourquoi, et comment révoquer le consentement.

10.3 SQL Server, PostgreSQL et Oracle

Un connecteur de base de données ne doit jamais permettre à un utilisateur de faire exécuter directement du SQL généré par un LLM dans le MVP. Il indexe des vues ou requêtes préparées approuvées par un administrateur de données. L'accès temps réel ou text-to-SQL nécessite une menace, une sandbox et une gouvernance distinctes.

Aspect	SQL Server	PostgreSQL	Oracle
Authentification	Identité managée/Entra lorsque réseau compatible, sinon compte lecture seule.	Compte lecture seule, TLS et secret rotatif/certificat.	Compte lecture seule, wallet/certificat ou secret rotatif.
Périmètre	Vues, tables ou requêtes préparées allowlistées.	Schémas/vues allowlistés.	Schémas/vues allowlistés.
Incrémental	Change Tracking/CDC ou watermark approuvé.	Colonne watermark ; logical decoding uniquement en évolution contrôlée.	SCN/watermark ou mécanisme approuvé.
Identité d'un item	Clé primaire déclarée et sérialisée canoniquement ; aucune ligne indexée sans clé stable.		
Suppression	Tombstone/CDC si disponible, sinon snapshot de clés et réconciliation bornée.		
ACL	Mapping explicite d'une ou plusieurs colonnes vers utilisateurs/groupes externes. Sans mapping valide, dataset limité à un principal configuré ou non publiable.		
Réseau	Agent privé ou connectivité privée recommandée ; IP publiques allowlistées seulement si acceptées. TLS obligatoire.		
Protection	Timeout, limite de lignes/pages, isolation faible impact, plage de synchronisation et détection des scans coûteux.		

Configuration d'un dataset

- Nom métier et description.
- Vue/requête préparée versionnée et testée ; paramètres exclusivement système.
- Clé stable, colonne de version ou watermark et règle de suppression.
- Colonnes indexables, affichables, filtrables et explicitement exclues.
- Template de document logique transformant une ligne en contenu compréhensible.
- Mapping ACL et comportement en cas de principal inconnu.
- Classification, rétention, volumétrie estimée et fréquence.

10.4 APIs REST, ERP, CRM et connecteurs futurs

Type	Authentification	Synchronisation	ACL et limites
REST générique	OAuth2 client credentials, API key en coffre, mTLS selon source.	Pagination déclarative, cursor/since, webhook optionnel, mapping JSON versionné.	Mapping principal obligatoire ; SSRF bloquée ; hôtes allowlistés ; tailles et timeouts stricts.
Salesforce / CRM	OAuth2 et application dédiée.	API bulk/delta ou événements selon offre.	Sharing model complexe ; connecteur dédié avant certification.
Dynamics 365	Entra OAuth2 application.	API Dataverse, change tracking.	Rôles et équipes à reproduire ou périmètre explicite.
SAP / ERP	OAuth2, certificat ou agent privé.	OData/BAPI/extracteurs approuvés, fenêtres de charge.	Autorisation métier souvent contextuelle ; ne pas promettre l'ACL sans modèle validé.
Connecteur custom	Selon profil approuvé.	SDK interne ou dépôt contrôlé, manifest de capacités.	Threat model, test contractuel, quota et revue sécurité obligatoires.

Protection SSRF du connecteur REST

- Refuser loopback, link-local, metadata endpoints cloud, plages privées non explicitement autorisées et redirections vers ces destinations.
- Résoudre DNS à chaque connexion selon la stratégie anti-rebinding ; appliquer allowlist de domaines et ports.
- Limiter méthodes, taille de réponse, profondeur JSON, temps, redirections et compression.
- Ne jamais exposer au template de mapping un secret, un header d'authentification ou une primitive d'exécution.

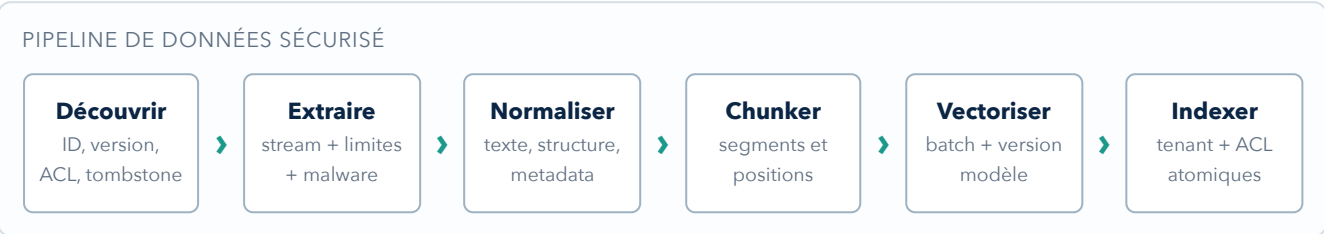
Critères d'acceptation – Connecteurs

- Chaque connecteur passe les tests de reprise, pagination, suppression, throttling, secret et isolation tenant.
- Une synchronisation peut être interrompue puis reprise sans doublon ni perte de curseur.
- Le statut et les erreurs sont compréhensibles par un TenantAdmin sans accès aux logs internes.
- Retirer un connecteur déclenche la suppression de toutes ses projections et laisse une preuve d'audit minimale.
- Un connecteur ne peut jamais choisir un tenant à partir de ses propres données.

11. Ingestion et synchronisation

11.1 Pipeline d'ingestion

Le pipeline est événementiel, partitionné par tenant/connecteur et idempotent. Chaque étape consomme un artefact immuable ou une référence, produit un nouvel état et enregistre sa progression. Une étape ne met pas silencieusement à jour plusieurs systèmes sans outbox ou mécanisme de réconciliation.



Étape	Entrée	Sortie	Contrôles	Échec
Discovery	Page source + curseur.	SourceltemDiscovered ou tombstone.	Tenant, clé stable, taille, type, version, ACL disponibles.	Item ignoré/quarantiné ; page checkpointée selon politique.
Fetch	Référence source.	Objet brut temporaire + hashes.	Timeout, streaming, limite, antivirus, type réel.	Retry transient ; quarantine permanent.
Parse	Objet brut.	Contenu structuré normalisé.	Sandbox extracteur, limite CPU/mémoire/pages.	ParseUnsupported ou ParseFailed.
Enrich	Texte + metadata source.	Métadonnées normalisées, langue, classification optionnelle.	Aucune génération de permission ; PII minimisée.	Enrichissement optionnel peut être omis.
Chunk	Structure normalisée.	Chunks ordonnés avec locators.	Respect paragraphes/titres/tableaux, overlap borné.	Document non indexable si aucun texte utile.
Embed	Chunks éligibles.	Vecteurs + EmbeddingProfileVersion.	Batch, quotas, région, redaction selon contrat.	Retry puis index lexical possible si mode dégradé autorisé.
Index	Document, chunks, vectors, ACL.	Projection searchable versionnée.	Écriture atomique/logique, tenant/ACL obligatoires.	Ancienne version reste active jusqu'au swap.
Finalize	Projection vérifiée.	Version courante, compteurs, audit technique.	Concordance nombre de chunks/hashes.	Compensations et réconciliation.

États d'un document

Discovered, Fetching, Processing, Ready, Quarantined, Unsupported, AccessUnknown, Deleting et Deleted. Seul Ready est recherachable. Une nouvelle version en traitement ne remplace pas la version Ready tant que contenu et ACL n'ont pas été indexés avec succès.

Métadonnées minimales d'index

Groupe	Champs requis	But
Isolation	OrganizationId, ConnectorId, DataSourceId.	Filtrage non contournable et exploitation.
Identité	DocumentId, DocumentVersionId, ChunkId, SourceItemId.	Dédoublonnage, citations et purge.
Contenu	Text, Title, Headings, ContentType, Language.	Recherche et affichage.
Localisation	SourceUri, page/section/row locator, ordinal.	Citation vérifiable.
Temps	SourceModifiedAt, IndexedAt.	Fraîcheur et ranking.
ACL	AllowedPrincipalKeys, DeniedPrincipalKeys si support, AclVersion.	Security trimming.
Version technique	SchemaVersion, ParserVersion, ChunkerVersion, EmbeddingProfileVersion.	Réindexation ciblée et reproductibilité.
Qualité	ParseWarnings, content hash, token count.	Diagnostic et coût.

11.2 Versionnement, chunking et déduplication

Hashes indépendants

Le système calcule au minimum ContentHash, MetadataHash et AclHash. Cette séparation évite de recalculer les embeddings lorsque seule une permission change et garantit qu'un changement ACL reste prioritaire. Le hash inclut une canonicalisation versionnée afin que son comportement soit reproductible.

Changement	Action
Aucun hash ni version source modifié	Ignorer de façon idempotente, mettre à jour uniquement la preuve de vérification.
ACL seulement	Mettre à jour filtre de document/chunks immédiatement, sans re-parser ni re-embedder.
Métadonnées filtrables seulement	Mettre à jour projection search ; re-embed uniquement si elles font partie du texte d'embedding.
Contenu	Créer DocumentVersion, parser, chunker, embedder puis swap atomique.
Parser/chunker/embedding profile	Créer une nouvelle projection technique, canary puis reindexation progressive.
SourceItemId nouveau mais hash identique	Conserver des documents logiques distincts si ACL/URI différent ; mutualisation physique facultative et invisible.

Politique de chunking

- Préserver les limites sémantiques : titres, paragraphes, listes, diapositives, feuilles et sections.
- Viser une taille configurable par type de document, avec overlap modéré et mesuré.
- Ne jamais fusionner des zones ayant des ACL différentes.
- Conserver position, page, feuille, cellule ou autre locator nécessaire à la citation.
- Versionner le chunker et réévaluer les paramètres avec un jeu de questions représentatif.

- Éviter les chunks contenant seulement navigation, pied de page répétitif ou données sans contexte.

11.3 Suppression, nettoyage et réconciliation

1. À réception d'un tombstone, marquer le document Deleting et retirer immédiatement sa projection searchable.
2. Supprimer ou rendre inaccessible contenu normalisé, chunks, vecteurs et caches selon la politique.
3. Conserver seulement les métadonnées minimales nécessaires à l'audit, sans contenu ni titre sensible si non requis.
4. Finaliser Deleted après confirmation de chaque système ; réessayer les sous-étapes de façon idempotente.
5. La réconciliation compare l'inventaire source et local, détecte les orphelins, versions bloquées, ACL obsolètes et projections manquantes.

Nettoyage périodique

- Objets temporaires expirés, multipart uploads incomplets et caches.
- Versions non courantes au-delà de la rétention et jobs terminés au-delà de leur fenêtre.
- Embeddings d'un profil retiré après bascule validée.
- Connecteurs supprimés, secrets orphelins, invitations expirées et exports arrivés à échéance.
- DLQ et quarantaines uniquement après résolution, expiration approuvée ou export de preuve.

Critères d'acceptation – Ingestion

- Rejouer un événement n'ajoute ni document, ni chunk, ni coût facturé en double.
- Une nouvelle version défectueuse ne remplace pas la dernière version saine.
- Un changement ACL sans contenu prend le chemin rapide et devient effectif dans le SLO.
- Une suppression source rend le document introuvable avant la purge physique complète.
- Chaque document Ready peut expliquer source, version, parser, chunker, embedding et ACL utilisés.

12. Recherche sécurisée

12.1 Recherche textuelle, vectorielle et hybride

La recherche hybride combine un score lexical utile pour les noms, codes et termes exacts avec un score vectoriel utile pour la similarité sémantique. Les candidats sont obtenus sous filtres tenant et ACL. Le système ne récupère jamais un ensemble non filtré pour éliminer ensuite les documents interdits dans l'application.



Flux normatif

1. Valider taille, langue et politique de contenu de la question.
2. Résoudre TenantContext, permission Search.Use, entitlement, quota et PrincipalSet.
3. Construire les filtres système immuables ; appliquer les filtres utilisateur uniquement comme restriction supplémentaire.
4. Créer l’embedding de requête avec le même profil compatible que l’index.
5. Exécuter lexical et vectoriel sous les mêmes contraintes de sécurité.
6. Fusionner, dédupliquer par document/version et diversifier les sources.
7. Reranker uniquement les candidats déjà autorisés.
8. Sélectionner les passages selon budget, score minimal, récence et diversité.
9. Enregistrer métriques et identifiants de preuve, sans journaliser le texte par défaut.

Filtres

Type	Origine	Modifiable par client	Exemples
Sécurité	Backend	Jamais	OrganizationId, ACL principals, document Ready, connecteur actif.
Entitlement	Backend	Jamais	Sources ou fonctionnalités autorisées.
Préférence	Utilisateur	Oui, en restriction	Site, type, plage de date, source.
Qualité	Search profile	Non directement	Langue, version embedding, score minimal.
Opération	Plateforme	Non	Index canary, région, feature flag.

12.2 Ranking, fraîcheur et qualité

Signal	Usage	Garde-fou
Score lexical	Termes exacts, acronymes, identifiants.	Analyseurs par langue, champs boostés versionnés.
Similarité vectorielle	Paraphrases et concepts.	Modèle/version compatible, seuil évalué.
Reranker	Réordonner une liste bornée.	Jamais sur un candidat non autorisé ; timeout et fallback.
Fraîcheur	Favoriser le récent lorsque la question l'implique.	Ne pas écraser une forte pertinence sans règle métier.
Autorité de source	Favoriser politique officielle vs brouillon si configuré.	Métadonnée administrée, pas estimée par le LLM.
Diversité	Éviter dix chunks du même passage.	Quota par document/source et fusion adjacente.
Feedback	Évaluer et entraîner le tuning.	Pas de modification directe du ranking individuel sans analyse.

Mesures de qualité de récupération

- Recall@K et nDCG@K sur un jeu de questions avec documents attendus.
- Taux de zéro résultat, taux d'abstention et couverture des citations.
- Fraîcheur : délai source → document searchable et délai ACL → filtre effectif.
- Latences p50/p95/p99 par étape, langue, tenant, source et profil.
- Tests adversariaux : identifiants proches, homonymes, questions cross-tenant et principaux incomplets.

MODE SANS RÉSULTAT

Si aucun passage ne franchit le seuil de qualité, le système n'invente pas une réponse. Il indique qu'il ne dispose pas de source suffisante et propose une reformulation ou des filtres, sans confirmer l'existence d'un document inaccessible.

Critères d'acceptation – Recherche

- Les filtres de sécurité sont visibles dans la trace technique et impossibles à retirer via le contrat client.
- Les jeux d'évaluation couvrent au moins deux tenants et des ACL contradictoires.
- Une recherche exacte et une paraphrase pertinente atteignent les seuils définis avant pilote.
- Le timeout du reranker déclenche un fallback déterministe sans élargir les résultats.
- Aucun texte de question ou résultat n'est loggé par défaut dans la télémétrie générale.

13. Intelligence artificielle et RAG

13.1 Génération de réponses et citations

Le service RAG orchestre une recherche sécurisée, construit un contexte borné, appelle le fournisseur IA et valide la forme de la réponse. Il produit une réponse fondée sur les extraits disponibles ou s'abstient. Une citation est une structure de données reliée à un passage utilisé, pas une URL inventée par le modèle.

Flux de réponse



1. Créer ou charger une conversation autorisée et prendre un verrou logique court sur le tour.
2. Persister le message utilisateur selon la politique de rétention, avec classification de sécurité.
3. Construire une requête de recherche à partir de la question et d'un historique strictement borné.
4. Récupérer uniquement des passages autorisés et enregistrer leurs identifiants/version.
5. Assembler un prompt versionné distinguant clairement instructions système, demande utilisateur et contenu non fiable des sources.
6. Appeler le modèle avec timeout, annulation et budget de sortie ; streamer les fragments textuels.
7. Résoudre les marqueurs de citation vers les objets connus ; supprimer ou signaler une citation inconnue.
8. Appliquer les contrôles de sortie, finaliser le message, le ledger d'usage et la trace.

Contrat de citation

Élément	Exigence
Identifiant	Référence interne opaque choisie par le backend avant l'appel modèle.
Affichage	Titre redacted si nécessaire, type, source, date et locator (page, section, feuille, ligne).
Lien	URL source ou endpoint proxy selon sécurité ; revalidation d'accès à chaque ouverture.
Version	DocumentVersionId utilisé au moment de répondre pour audit et reproductibilité.
Couverture	Chaque affirmation importante doit être associée à au moins une citation ou être formulée comme incertaine/non sourcée.
Suppression	Si la source disparaît, conserver au plus une référence redacted selon politique ; ne pas conserver le contenu via la citation.

Réduction des hallucinations

- Seuil minimum de récupération et abstention explicite si preuves insuffisantes.
- Instructions de réponse fondée uniquement sur le contexte pour les questions internes.

- Température faible et format de citation structuré lorsque le fournisseur le permet.
- Vérification de l'existence des citations et de leur correspondance aux passages.
- Évaluations de faithfulness, answer relevance, citation precision et completeness.
- Signal clair lorsqu'une réponse utilise une connaissance générale autorisée ; mode interne strict par défaut.
- Feedback utilisateur et file de revue sur échantillons redacted, avec consentement/politique.

13.2 Sécurité IA et prompt injection

Tout contenu récupéré est considéré comme non fiable : un document peut contenir des instructions visant le modèle. Le système sépare structurellement les instructions et les données, réduit les capacités de l'agent et interdit au modèle de déclencher une action sensible sans validation déterministe.

Menace	Contrôles	Limite assumée
Prompt injection directe	Validation entrée, hiérarchie d'instructions, outils allowlistés, confirmation des actions.	Aucun filtre textuel n'est parfait ; limiter les conséquences.
Injection indirecte dans document	Balitage comme contenu non fiable, détection heuristique, aucun secret dans le contexte, aucune autorisation déléguée au modèle.	Le modèle peut être influencé ; les contrôles externes restent la barrière.
Exfiltration inter-tenant	Recherche tenant/ACL avant contexte, cache partitionné, fournisseurs configurés sans entraînement selon contrat.	Zéro confiance envers une instruction de prompt.
Fuite du prompt système	Aucun secret ou contrôle critique dans le prompt ; réponse de refus ; tests adversariaux.	Le prompt est considéré divulguable.
Sortie dangereuse	Modération/policies selon cas, encodage UI, liens sécurisés, pas d'exécution HTML.	Les faux positifs sont suivis.
Tool abuse futur	Scopes minimaux, arguments validés, dry-run, approbation humaine, idempotence et audit.	Les outils d'écriture sont hors MVP.
Denial of wallet	Limites tokens, taille contexte, quotas, rate limits, timeout, routage modèle.	Les coûts externes sont surveillés quasi temps réel.

ACTIONS AGENTIQUES

Le MVP est en lecture seule. Toute future capacité d'écrire dans un ERP, CRM, email ou document doit faire l'objet d'un module distinct : permission spécifique, aperçu de l'action, confirmation humaine, limites de portée, idempotence, compensation et audit complet.

Gestion des prompts

- Templates versionnés, revus et promus entre environnements comme un artefact.
- Variables typées, délimitées et échappées ; pas de concaténation libre de configuration.
- Association de chaque réponse à PromptVersion, ModelDeployment et RetrievalProfile.
- Rollout canary et A/B uniquement avec critères de qualité et confidentialité.
- Rollback immédiat possible sans redéploiement de l'API.
- Les prompts tenant personnalisables sont limités à des instructions sûres et ne peuvent désactiver citations, ACL ou policies.

13.3 Fournisseurs IA, modèles et changement futur

DÉCISION ADR-005

Utiliser deux abstractions distinctes : GenerationProvider et EmbeddingProvider. Un ModelRegistry mappe un profil fonctionnel vers un déploiement, une région, des capacités, limites et politiques de données. Ne pas exposer un nom de modèle fournisseur comme règle métier.

Composant	Responsabilité	Données versionnées
ModelProfile	Décrire capacité attendue : qualité, contexte, streaming, structured output, coût maximal.	Identifiant interne, version, fallback.
ProviderDeployment	Adresse un fournisseur/région/déploiement réel.	Fournisseur, modèle, région, limites, statut.
DataPolicy	Contraintes de rétention, entraînement, résidence et contenu autorisé.	Version contractuelle et date de validation.
RoutingPolicy	Choisir déploiement selon tenant, feature, langue, santé, coût.	Ordre et conditions, sans donnée sensible.
EmbeddingProfile	Dimension, modèle, normalisation et stratégie de migration.	Immuable après indexation.
UsageRecord	Mesurer tokens, latence, coût estimé et résultat.	Tenant, profil, corrélation, sans prompt par défaut.

Fallback

Le fallback n'est permis que vers un déploiement dont la politique de données, la région et les capacités sont compatibles avec le tenant. Un changement de modèle susceptible d'altérer la qualité doit être canaryé et évalué. Pour les embeddings, deux versions d'index coexistent pendant migration ; il n'existe pas de conversion fiable d'un vecteur entre modèles.

Historique et mémoire

- L'historique de conversation est une donnée tenant et utilisateur, soumise à rétention et suppression.
- Chaque tour reconstruit les droits et refait la recherche ; un chunk ancien n'est pas réinjecté sans revalidation.
- Une synthèse de conversation peut réduire les tokens mais reste non fiable, versionnée et supprimable.
- La mémoire inter-conversations est désactivée au MVP ; si ajoutée, elle exige consentement, visibilité et suppression dédiés.
- Les données de conversation ne servent pas à entraîner un modèle sans base contractuelle et fonctionnalité explicite.

Critères d'acceptation – IA/RAG

- Une réponse peut être reliée au modèle, prompt, profil search et versions de documents utilisés.
- Une citation inconnue générée par le modèle n'est jamais transformée en lien valide.
- Le système s'abstient lorsque les preuves sont insuffisantes ou la recherche indisponible.
- Le fallback respecte les politiques de données du tenant.
- Les tests de prompt injection démontrent qu'un document ne peut ni élargir l'ACL ni exécuter une action.

14. Conversations et expérience utilisateur

14.1 Modèle fonctionnel

Objet	Comportement	Contraintes
Conversation	Conteneur nommé, privé par défaut, propriétaire, date d'activité et visibilité.	Même tenant ; état Active, Archived, Deleting, Deleted.
Message utilisateur	Question, pièces jointes futures, date, état de traitement.	Taille, type, modération/policy et rétention.
Message assistant	Réponse, statut, citations, modèle, usage, éventuelle raison d'abstention.	Immuable après finalisation sauf redaction/suppression.
Favorite	Attribut personnel sur conversation.	Pas de conséquence sur partage ou rétention.
ShareGrant	Accès explicite à un membre/groupe ou lien interne contrôlé.	Même tenant, expiration, révocation, audit.
Feedback	Utile/non utile, catégorie et commentaire optionnel.	Accès au message, PII minimisée, usage qualité documenté.

14.2 Comportements attendus

Création et réponse

- Une conversation est créée explicitement ou atomiquement avec le premier message.
- Le titre est dérivé de façon asynchrone et peut être modifié par le propriétaire.
- Le streaming affiche les phases utiles : recherche, génération, finalisation, sans révéler la chaîne de pensée du modèle.
- L'annulation stoppe l'appel fournisseur lorsque possible et marque le message Cancelled ; elle ne laisse pas un message final incohérent.
- Un retry utilisateur crée une nouvelle tentative liée au message initial, avec nouvelle recherche et droits courants.

Historique et recherche

- La liste est paginée par dernière activité et filtrable par titre, favoris, date et propriétaire/partage.
- La recherche dans l'historique n'indexe que les conversations accessibles et respecte les suppressions.
- Le contenu complet des sources citées n'est pas dupliqué dans la conversation ; seuls les passages nécessaires et références suivent la rétention définie.
- L'ouverture d'une ancienne citation revalide tenant, membre, partage et ACL source actuels.

Partage

SÉMANTIQUE DE PARTAGE

Partager une conversation ne partage pas les documents cités. Chaque destinataire voit la réponse, mais l'ouverture des citations et toute nouvelle génération sont recalculées selon ses propres ACL. Si le risque de révélation dans le texte de réponse est incompatible avec cette règle, le partage doit être limité ou produire une version redacted.

Pour le MVP, le partage est désactivé. En production générale, il est activable par tenant et limité à l'organisation. Le propriétaire choisit les destinataires ; le système prévient que le texte peut contenir des informations auxquelles ceux-ci n'ont pas accès. La recommandation sécurisée est de régénérer une vue partageable à partir de l'intersection des accès, ou de restreindre le partage aux membres dont le système confirme l'accès aux citations au moment du partage.

Suppression et conservation

- La suppression utilisateur retire immédiatement la conversation des listes et révoque les partages.
- Une purge asynchrone traite messages, index d'historique, pièces jointes, caches et artefacts IA.
- Les compteurs financiers et audits sont conservés sous forme minimisée si requis.
- Un legal hold autorisé bloque la purge physique tout en masquant la conversation à l'usage normal.
- La rétention par défaut et les bornes configurables sont visibles par le TenantAdmin.

Critères d'acceptation – Conversations

- Un membre ne peut pas deviner ou ouvrir l'identifiant d'une conversation d'un autre tenant.
- Le propriétaire peut supprimer, archiver, renommer, rechercher et mettre en favori.
- Une citation dont l'accès a été retiré n'ouvre plus le document.
- Un partage révoqué cesse immédiatement d'autoriser les lectures suivantes.
- La purge couvre le stockage primaire, l'index d'historique et les caches.

15. Audit et journalisation

15.1 Séparation des signaux

Signal	Finalité	Contenu	Accès
Audit métier	Prouver qui a fait quoi, quand, sur quelle ressource et avec quel résultat.	Événement structuré append-only, acteur, action, cible, changements minimisés, corrélation.	TenantAdmin/Auditor pour son tenant ; sécurité plateforme selon procédure.
Log applicatif	Diagnostiquer le comportement du logiciel.	Messages structurés, niveau, code, composants, identifiants techniques.	Équipe d'exploitation ; pas d'accès tenant direct.
Trace distribuée	Suivre une requête à travers API, file, worker, source, search et IA.	Spans, durée, statut, attributs à faible cardinalité.	Opérations et ingénierie.
Métrique	Mesurer santé, capacité, SLO et usage agrégé.	Compteurs, histogrammes, gauges.	Dashboards plateforme et vues tenant agrégées.
Ledger d'usage	Quota, coût et facturation.	Quantité, unité, période, clé d'idempotence.	TenantAdmin selon offre ; finance et plateforme.

15.2 Événements d'audit obligatoires

Catégorie	Événements	Résultat à enregistrer
Identité	Admission acceptée/refusée, provisionnement, liaison IdP, suspension, réactivation.	Success/Denied/Failed, policy utilisée, acteur externe redacted.
Autorisation	Rôle accordé/retiré, élévation support, changement de policy.	Ancienne/nouvelle valeur et justification.
Organisation	Paramètres, rétention, région, feature sensible, suspension tenant.	Diff de champs non secrets.
Connecteurs	Création, consentement, secret remplacé, périmètre, pause, sync manuelle, suppression.	Type, ressource, jamais la valeur secrète.
Données	Export, purge, legal hold, réindexation globale, accès support au contenu.	Périmètre, volume, destination et approbation.
Conversations	Partage, révocation, suppression administrative.	Conversation opaque et destinataires internes.
Commercial	Plan, entitlement, quota override, crédit.	Valeur, période et source de décision.
Sécurité	Refus répétés, rotation de clés, configuration affaiblie, incident.	Indicateurs actionnables sans détails exploitables.

Schéma d'événement

Chaque événement inclut EventId, TimestampUtc, OrganizationId lorsque pertinent, ActorType, ActorId interne ou empreinte externe, Action, ResourceType, ResourceId, Outcome, ReasonCode, CorrelationId, SourceId tronquée/hachée selon politique, UserAgent normalisé et Metadata allowlistée. Le payload est versionné.

Intégrité et conservation

- L'audit est append-only pour les applications. Une correction crée un nouvel événement.
- Le stockage applique contrôle d'accès séparé, chiffrement, immutabilité ou mécanisme de détection d'altération.
- Les exports sont signés ou accompagnés d'un hash et d'une chaîne de génération.
- La rétention est définie par catégorie et offre ; les prompts et contenus ne sont pas inclus par défaut.
- Les horloges sont synchronisées et la précision est documentée.

15.3 Journalisation sûre

INTERDICTIONS

Ne jamais journaliser access tokens, refresh tokens, cookies, assertions SAML, secrets, chaînes de connexion, corps complets de documents, embeddings, prompts ou réponses en production générale. Toute capture temporaire exige un mécanisme dédié, un tenant consentant, une durée courte, une redaction et un audit.

Donnée	Traitement de log
OrganizationId, ConnectorId, JobRunId	Autorisés comme identifiants corrélables ; contrôler cardinalité.
MemberId	Identifiant interne autorisé si nécessaire ; pas d'email en attribut courant.
URL source	Hôte ou hash ; chemin et query redacted par défaut.
Question/réponse	Longueur, langue, hash non réversible optionnel et classification ; texte exclu.
Erreur fournisseur	Code, statut, RequestId fournisseur ; body filtré.
Exception	Stack trace en backend sécurisé ; message contrôlé vers client.

Critères d'acceptation – Audit

- Un changement de rôle ou de connecteur est retrouvable par acteur, cible, date et corrélation.
- Un TenantAdmin ne peut ni modifier ni supprimer l'audit.
- Un scan automatisé ne trouve aucun secret ou token dans les logs de test.
- Les événements refusés importants sont enregistrés sans révéler une ressource d'un autre tenant.
- Un export d'audit est chiffré, expire et son téléchargement est lui-même audité.

16. Sécurité, vie privée et conformité

16.1 Modèle de menaces

Un threat model est maintenu par flux de données et révisé avant chaque nouvelle famille de connecteur, fournisseur IA, mécanisme de partage ou capacité d'écriture. Le tableau suivant fixe les scénarios minimaux.

Menace	Actif	Contrôles préventifs	Détection / réponse
Fuite inter-tenant	Toutes données client.	TenantContext, filtres stockage, index et cache, tests systématiques, ressources dédiées optionnelles.	Canaries, audit, alertes d'anomalie, procédure incident critique.
Broken object authorization	Membres, connecteurs, conversations.	Policies ressource, tenant dérivé du jeton, 404 uniforme.	Tests DAST et logs de refus corrélés.
Vol de credentials connecteur	Sources client.	Coffre, identités managées, certificats, rotation, aucun retour API.	Audit d'accès secret, détection d'usage, révocation.
Supply chain	Runtime et pipeline.	Lockfiles, provenance, SBOM, signatures, scans SCA/container.	Alertes CVE, patch SLA et blocage release critique.
Fichier malveillant	Workers et parsers.	Antivirus, sandbox, limites ressources, bibliothèques maintenues.	Quarantaine et alerte par signature/taux.
SSRF	Réseau interne et metadata cloud.	Egress proxy, allowlists, validation DNS/IP, connecteur REST durci.	Logs réseau, deny alerts et kill switch.
Prompt injection	Réponses, outils et données.	ACL avant contexte, séparation instructions/données, lecture seule, aucun secret en prompt.	Évaluations adversariales et signalement utilisateur.
Exfiltration par support	Contenu client.	Pas d'accès par défaut, JIT support, approbation et session limitée.	Audit immuable et revue périodique.
Abus / déni de service	Disponibilité et coûts.	Rate limits, quotas, taille, timeout, backpressure et WAF.	Alertes saturation/coût, limitation adaptative.
Suppression incomplète	Vie privée et contrat.	Catalogue de données, orchestrateur de purge, statuts par système.	Rapport de purge et réconciliation.

Protection API

- TLS moderne obligatoire ; HSTS ; redirection HTTP désactivée au profit d'un refus sur les surfaces privées si approprié.
- Validation stricte des tokens, CORS allowlisté, CSP et protections frontend adaptées.
- WAF/API gateway pour limites de taille, réputation, règles génériques et DDoS du fournisseur.
- Rate limits distribués par IP, tenant, membre et endpoint coûteux.
- Mass assignment évité par contrats dédiés ; champs serveur non bindables.
- Sorties encodées ; markdown de réponse rendu via allowlist sans HTML actif, script, iframe ou URL dangereuse.

- Uploads futurs analysés, renommés et servis avec headers de téléchargement sûrs.

Chiffrement et clés

Zone	Exigence
En transit	TLS pour clients et dépendances ; mTLS ou private links pour intégrations sensibles lorsque possible.
Au repos	Chiffrement fournisseur pour SQL, objets, search, cache persistant, sauvegardes et files.
Clés	Coffre/KMS, séparation environnement, rotation, accès par identité de workload et journalisation.
Tenant dédié	Clé gérée par le client ou clé dédiée possible selon offre et architecture de stamp.
Application	Chiffrement applicatif ciblé pour credentials ou champs très sensibles si le coffre ne suffit pas ; clés jamais dans le même stockage.

Gestion des secrets

- Aucun secret dans appsettings versionné, code, image, logs ou base applicative en clair.
- Développement local via mécanisme de secrets utilisateur ou coffre de développement.
- QA/UAT/PROD utilisent identités de workload et coffre séparé ; pas de partage de credential.
- Rotation testée, alertée avant expiration et réalisable sans interruption majeure.
- Révocation immédiate et procédure documentée pour incident.

16.2 Vie privée, RGPD et conformité

Le produit applique limitation des finalités, minimisation, exactitude, limitation de conservation, intégrité et responsabilité démontrable. Le client reste généralement responsable de traitement pour ses contenus ; le SaaS agit selon le contrat et les instructions documentées. Les rôles exacts doivent être confirmés juridiquement.

Exigence	Implémentation produit	Preuve
Inventaire des traitements	Catalogue des données par module, finalité, localisation, sous-traitant et rétention.	Registre maintenu et revue de changement.
Minimisation	Claims limités, logs redacted, contenu envoyé au LLM limité aux passages nécessaires.	Schémas, tests de log et inspection de traces.
Transparence	Notice, liste des fournisseurs, régions, usage de l'IA et politique de conservation accessibles.	Version de notice acceptée/configurée.
Accès / portabilité	Export utilisateur et tenant dans un format documenté.	Demande, identité vérifiée, export et téléchargement audités.
Rectification	Profil synchronisé depuis IdP ou modifiable selon source de vérité.	Historique des changements pertinents.
Effacement	Orchestration de purge couvrant primaire, search, objets, caches et conversations.	Rapport de purge ; sauvegardes expirées selon calendrier.
Restriction / legal hold	État qui bloque l'usage tout en suspendant une purge autorisée.	Policy, approbation et audit.

Exigence	Implémentation produit	Preuve
Résidence	Région du tenant et routage de tous les services compatibles.	Inventaire de ressources et tests de configuration.
Sous-traitants	Registre de fournisseurs IA/cloud et mécanisme de changement contractuel.	DPA, SCC le cas échéant, revue sécurité.
Incident	Runbook de qualification, confinement, preuve et notification.	Exercices et chronologie d'incident.

Durées de conservation proposées

Donnée	Baseline proposée	Configurabilité
Conversations	90 jours pour pilote.	30 à 365 jours, ou historique désactivé selon offre/politique.
Documents indexés	Tant que présents à la source et connecteur actif.	Cache de suppression immédiat ; versions historiques limitées.
Logs applicatifs	30 jours chaud + archive courte selon besoin.	Plateforme, non ajustable librement par tenant.
Audit tenant	12 mois.	12 à 24 mois selon offre et obligation.
Jobs et diagnostics	90 jours.	Selon criticité ; payload contenu exclu.
Exports	24 heures.	Maximum court défini par sécurité.
Sauvegardes	35 jours indicatifs.	Selon RPO/RTO, contrat et région.
Ledger de facturation	Selon obligations financières applicables.	Validé juridiquement.

CONFORMITÉ PROGRESSIVE

Préparer les contrôles et preuves pour SOC 2 / ISO 27001 dès la fondation : inventaire, contrôle d'accès, gestion des changements, incidents, risques fournisseurs, sauvegardes et revue périodique. La certification elle-même est un programme organisationnel distinct du développement produit.

Critères d'acceptation – Sécurité et conformité

- Un threat model approuvé couvre identité, connecteurs, ingestion, recherche, IA et support.
- Aucun secret n'est présent dans le dépôt ou les artefacts ; les scans bloquent la release.
- Les tests d'autorisation inter-tenant et ACL sont bloquants dans la CI.
- Une demande d'export et une demande d'effacement sont exécutables et auditable de bout en bout.
- Le registre des données indique pour chaque stockage le propriétaire, la région, la rétention et la purge.

17. Infrastructure et environnements

17.1 Topologie cible

L'infrastructure est définie comme code et déployée en « stamps » régionaux. Un stamp contient API, workers, base, file, cache, stockage et index compatibles. Le plan de contrôle global ne conserve que le minimum nécessaire au routage et à la facturation. Un tenant est assigné à un stamp et ne migre qu'au travers d'un processus explicite.

Composant	Mode	Scalabilité	Haute disponibilité
API	Conteneurs/stateless derrière gateway.	Horizontal selon CPU, requêtes et latence.	Au moins deux instances en production, zones si disponibles.
Workers sync	Pool par types de connecteur.	Backlog, débit et throttling source.	Leases et messages rejouables.
Workers ingestion/embedding	Pools séparés par profil de charge.	Backlog, CPU/mémoire, quotas fournisseur.	Idempotence et checkpoints.
SQL	Service managé.	Scale-up initial, read replicas ciblées si besoin.	Zone/replica, PITR et failover testé.
Bus/file	Service managé topics/queues.	Partitions et consumer groups.	Durabilité, DLQ et réplication fournisseur.
Search	Cluster/service managé.	Partitions, replicas, index par stamp/version.	Replicas ; reconstruction depuis source de vérité.
Object storage	Service managé privé.	Élastique.	Réplication selon région et exigences.
Cache	Cluster managé.	Mémoire/partitions.	Perte tolérée ; aucune donnée unique.

17.2 Configuration et feature flags

Hiérarchie de configuration

1. Valeurs par défaut sécurisées livrées avec l'application.
2. Configuration d'environnement non secrète, validée au démarrage.
3. Références de secrets résolues par identité de workload.
4. Paramètres de stamp/région.
5. Paramètres tenant allowlistés et validés.
6. Feature flags ; ils ne peuvent pas désactiver une barrière de sécurité fondamentale.

Type de flag	Usage	Exemple	Gouvernance
Release	Découpler déploiement et activation.	Nouveau reranker.	Propriétaire, date d'expiration, métrique de succès.
Experiment	Comparer deux comportements.	Profil de chunking.	Consentement/données compatibles, échantillon et fin programmée.
Operational	Kill switch ou réduction de charge.	Pause embedding d'un fournisseur.	Accessible on-call, changement audité.
Entitlement	Non recommandé comme flag.	Connecteur Oracle.	Doit vivre dans EntitlementService.

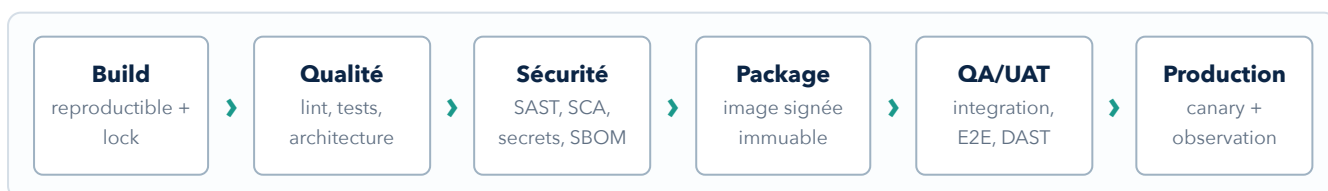
Environnements

Environnement	Données	Accès	Déploiement	But
Local	Synthétiques uniquement.	Développeur.	À la demande.	Développement rapide et tests locaux.
DEV	Synthétiques, tenants de test.	Équipe technique.	Continu depuis branche principale.	Intégration et observabilité.
QA	Synthétiques représentatives.	QA et équipe.	Artefact candidat immuable.	Intégration, E2E, sécurité et régression.
UAT	Données dédiées approuvées, idéalement synthétiques.	Utilisateurs pilotes nommés.	Promotion contrôlée.	Validation métier et onboarding.
PROD	Données client réelles.	Utilisateurs et opérations JIT.	Progressif avec approbation.	Service contractuel.

Aucun dump de production n'est copié dans un environnement inférieur. Les IdP, applications OAuth, coffres, clés, bases, files, index et fournisseurs IA sont séparés. Les données de tests intègrent des canaries permettant de détecter un routage vers le mauvais environnement.

17.3 CI/CD, stratégie de release et rollback

Pipeline de validation



- Un commit produit un artefact unique promu entre environnements ; aucune recompilation pour PROD.
- Les migrations de base suivent « expand, migrate, contract » et restent compatibles avec la version N-1 pendant le rollout.
- Le déploiement production commence par un faible pourcentage ou un stamp canary, puis augmente après validation des SLO.

- Les feature flags contrôlent l'activation fonctionnelle ; le rollback binaire reste possible.
- Le rollback ne suppose pas une migration destructive inverse. Les changements contractants attendent la stabilité et une sauvegarde vérifiée.
- Les schémas d'événement et d'index sont versionnés ; consumers tolérants aux champs additifs.

Conditions de promotion

- ▣ Tests unitaires, intégration, architecture, isolation tenant et ACL réussis.
- ▣ Aucune vulnérabilité critique/haute non acceptée ; aucun secret détecté.
- ▣ Migrations testées sur volume représentatif avec durée et locks mesurés.
- ▣ Dashboards, alertes, runbook et rollback associés à la fonctionnalité existent.
- ▣ Évaluations RAG et budget de coût respectent les seuils.
- ▣ Product Owner, QA et sécurité approuvent selon matrice de risque.

17.4 Sauvegardes et reprise après incident

Système	Source de vérité	RPO cible initial	RTO cible initial	Stratégie
SQL primaire	Oui.	≤ 15 minutes.	≤ 4 heures.	PITR, sauvegardes chiffrées, réplication et restauration testée.
Object storage normalisé	Oui ou reconstruisible selon artefact.	≤ 1 heure.	≤ 8 heures.	Versioning, soft delete borné, réplication selon région.
Search index	Non.	N/A ; reconstruction.	≤ 24 heures pour corpus pilote.	Schéma versionné et reindexation depuis métadonnées/objets.
Bus/file	Temporaire mais critique.	Selon rétention des messages.	≤ 4 heures.	Durabilité fournisseur, outbox, replay et DLQ.
Cache	Non.	0.	Minutes.	Reconstruction ; perte tolérée.
Audit	Oui.	≤ 15 minutes.	≤ 8 heures.	Stockage durable/immuable et export de secours.

Ces objectifs sont une baseline de conception à valider commercialement. Un exercice de restauration est effectué au moins trimestriellement avant GA. Le runbook définit déclaration, commandement, communication client, failover, validation d'intégrité, reprise des jobs, réconciliation et post-mortem.

Critères d'acceptation – Infrastructure

- Tous les environnements sont reproductibles par infrastructure as code et isolés.
- Une release peut être canaryée, stoppée et rollbackée sans improvisation.
- Une restauration SQL et une reconstruction d'index sont chronométrées et documentées.
- Les workers absorbent un retry/replay sans doublon métier.
- Chaque feature flag a un propriétaire, une valeur sûre et une date de retrait.

18. Observabilité et exploitation

18.1 Standards de télémétrie

OpenTelemetry instrumente API, handlers, repositories, bus, workers, appels source, search et fournisseurs IA. Le contexte de trace est propagé dans les messages. Les attributs utilisent des identifiants internes et évitent les contenus, emails, URLs complètes et cardinalités non bornées.

Composant	Métriques clés	Traces clés
API	RPS, statut, latence p50/p95/p99, 401/403/429/5xx, connexions stream.	Gateway → auth → handler → persistence/dépendance.
Identity	Bootstrap, admissions, refus, JIT, cache groupe, latence JWKS.	Validation → tenant → membre → policies.
Connecteurs	Items/s, bytes, âge curseur, 401/403/429, retries, partitions.	Sync run → page → item → événement.
Ingestion	Backlog, durée par étape, quarantaine, coût embedding, délai source-to-index.	Item → fetch → parse → chunk → embed → index.
Search	Latence lexical/vector/rerank, zéro résultat, K, score, timeouts.	Question → principal set → query → sélection.
IA	TTFT, durée, tokens in/out, coût, erreurs, fallback, abstention.	Prompt build → provider → validation → persist.
Conversations	Création, messages, annulations, partages, suppressions.	Request → policy → storage → purge.
Infrastructure	CPU, mémoire, connexions DB, locks, queue depth, search capacity, cache eviction.	Corrélation avec saturation et déploiements.

18.2 SLI, SLO et budgets d'erreur

Parcours	SLI	SLO initial	Exclusions contrôlées
API interactive	Requêtes valides servies sans 5xx imputable plateforme.	99,9 % mensuel.	Maintenance annoncée et dépendance client explicitement identifiée.
Bootstrap	Latence serveur p95.	< 750 ms hors premier JIT et IdP externe.	Cold start à éliminer en PROD.
Recherche	Latence p95 jusqu'aux résultats.	< 2 s sur corpus pilote.	Reranker dégradé avec fallback.
Réponse RAG	Time to first token p95.	< 5 s.	Fournisseur en incident identifié, avec statut utilisateur.
Sync delta	Âge p95 d'un changement source indexé.	< 15 min pour sources configurées à 5 min.	Throttling ou indisponibilité source visible.

Parcours	SLI	SLO initial	Exclusions contrôlées
Révocation ACL	Délai p99 retrait source → introuvable.	< 5 min après événement reçu ; réconciliation 24 h.	Aucune exclusion silencieuse.
Purge utilisateur	Demandes terminées dans la fenêtre.	99 % < 24 h hors backup lifecycle/legal hold.	Exception justifiée et visible.

Dashboards

- Vue exécutive : disponibilité, SLO, incidents, tenants actifs et coûts.
- Vue API : trafic, erreurs, latences, auth, rate limits et déploiements.
- Vue données : backlog, sync freshness, ingestion, quarantaines et ACL lag.
- Vue RAG : retrieval, TTFT, tokens, coûts, abstentions, citations et feedback.
- Vue tenant : santé des connecteurs, quotas, usage et incidents affectant ce tenant.
- Vue sécurité : refus anormaux, accès support, secrets, exports et canaries.

Alertes actionnables

Alerte	Seuil indicatif	Action
Burn rate disponibilité	Consommation rapide du budget d'erreur sur fenêtres courte/longue.	Page on-call, stop rollout, runbook API.
ACL lag	p99 au-dessus du SLO ou backlog de priorité sécurité.	Page critique, pause génération concernée si accès incertain.
Backlog ingestion	Âge du message croissant au-delà de la capacité.	Scale workers, vérifier fournisseur et poison messages.
Auth failures connector	401/403 répétés sur une instance.	Passer NeedsReauthorization et notifier TenantAdmin.
Coût IA anormal	Dérive par tenant/profil ou budget journalier.	Limiter, examiner abus/configuration, informer sans fuite.
Quarantine spike	Taux supérieur à baseline par parser/source.	Stop canary parser et diagnostiquer.
Canary inter-tenant	Tout résultat inattendu.	Incident critique, désactiver chemin affecté.

18.3 Exploitation et support

Chaque alerte de page possède un runbook avec impact, vérifications, commandes sûres, mitigation, escalation, communication et critères de résolution. Les outils de support affichent la santé et les métadonnées par défaut, pas le contenu. Un accès au contenu exige un ticket client, une approbation, une durée et un motif.

- Rotation on-call et niveaux de sévérité définis.
- Modèles de communication incident client et statut public.
- Post-mortem sans blâme pour incidents significatifs, actions suivies.
- Revue hebdomadaire des erreurs récurrentes, DLQ et quarantaines.
- Revue mensuelle SLO, coûts, capacité et risques de sécurité.

Critères d'acceptation – Observabilité

- Une question peut être suivie de l'API jusqu'au fournisseur IA sans exposer son texte.
- Un item source peut être suivi jusqu'à la version indexée ou sa quarantaine.
- Chaque alerte critique possède un runbook testé et un propriétaire.
- Les dashboards séparent incident plateforme, source client et fournisseur externe.
- Un déploiement apparaît dans les métriques et traces pour corréler une régression.

19. Performance et scalabilité

19.1 Budgets de latence

Étape interactive	Budget p95 indicatif	Optimisation principale
Gateway + auth + contexte	300 ms	Validation locale JWKS, caches courts tenant/membre, pas d'appel Graph par requête.
Embedding de requête	500 ms	Modèle régional, connexion réutilisée, timeout.
Recherche hybride	800 ms	Index filtrable, partitions adaptées, K borné.
Reranking	600 ms	Petite liste, modèle rapide, fallback.
Assemblage du prompt	100 ms	Budget et métadonnées pré-calculées.
Premier token modèle	2 500 ms	Streaming, déploiement sain et contexte borné.

Ces budgets sont des objectifs de capacité, pas une addition contractuelle stricte. Ils sont recalibrés après mesures sur le corpus pilote, notamment pour les régions, langues et modèles sélectionnés.

19.2 Principes de scalabilité

- API stateless ; aucun état de conversation uniquement en mémoire.
- Workers indépendants par profil de charge afin qu'un parsing lourd ne bloque pas les deltas ACL.
- Priorités de file : révocations/suppressions, changements ACL, interactif, delta contenu, initial/backfill.
- Fair scheduling et quotas de concurrence par tenant pour empêcher un gros import d'affamer les autres.
- Batching pour embeddings et écritures index, borné par taille et latence.
- Backpressure de bout en bout ; la file n'est pas une capacité infinie.
- Partitionnement mesuré sur OrganizationId/ConnectorId ; éviter les hot partitions.
- Scale-out fondé sur backlog age et latence, pas seulement CPU.

19.3 Cache

Donnée	TTL indicatif	Invalidation	Interdit
Tenant actif/config minimale	1 à 5 min.	Événement de changement/suspension.	Servir un tenant suspendu après événement reçu.
Permissions membre	1 à 5 min.	Changement rôle/statut.	Clé sans tenant et membre.
Group memberships	Court, selon IdP.	Événement/delta ou expiration.	Utiliser une valeur stale lorsque l'ACL est incertaine.
Résultat de recherche	Désactivé au MVP ou secondes.	Version ACL/index.	Partager entre users sans principal-set identique.

Donnée	TTL indicatif	Invalidation	Interdit
Réponse RAG	Pas de cache partagé par défaut.	N/A.	Réutiliser sans revalider ACL, versions et contexte.
JWKS/OIDC metadata	Selon bibliothèque et headers.	Rollover/refresh sur kid inconnu.	Clés figées dans le binaire.

19.4 Pagination, concurrence et base de données

- Pagination curseur et projection des colonnes nécessaires ; aucun chargement de collection entière.
- Index SQL alignés avec OrganizationId, statut, clés externes et ordres de liste.
- AsNoTracking pour lecture et transactions courtes pour mutations.
- Concurrence optimiste sur agrégats administratifs ; verrous distribués limités aux jobs/leases.
- Outbox écrite dans la même transaction que l'état métier puis publiée asynchronement.
- Connection pooling, timeouts, cancellation tokens et limite de concurrence vers chaque dépendance.
- Requêtes lentes observées, budgets d'exécution et plans vérifiés sur volumétrie représentative.

Hypothèses de capacité pilote

Dimension	Hypothèse de dimensionnement	Test requis
Tenants	10 pilotes, isolation logique.	Charge mixte et noisy neighbor.
Membres	Jusqu'à 5 000 par tenant pilote.	Bootstrap et pagination.
Documents	Jusqu'à 1 million par grand tenant pilote.	Initial sync, index et purge.
Chunks	5 à 10 millions selon corpus.	Recherche hybride et coût.
Concurrence chat	100 requêtes simultanées par stamp initial.	Streaming, quotas et fournisseur IA.
Ingestion	Backfill massif + trafic interactif.	Priorités et fair scheduling.

Critères d'acceptation – Performance

- Les SLO sont atteints sur un corpus et une charge représentatifs, pas sur une base vide.
- Un tenant en backfill ne dégrade pas l'API interactive des autres au-delà du budget.
- Les priorités permettent à une révocation ACL de dépasser un backlog de contenu.
- Les quotas et annulations limitent réellement les appels IA et embeddings.
- Le plan de capacité indique les seuils de scale et le coût par unité utile.

20. Stratégie de tests et qualité

20.1 Pyramide et responsabilités

Niveau	Cible	Exemples critiques	Exécution
Unitaires	Domaine, politiques, normalisation, scoring et transitions.	Dernier admin, admission, ACL allow/deny, hash/version, quotas.	Chaque PR, rapides et déterministes.
Architecture	Dépendances et conventions.	Domain sans EF/HTTP, handlers sans logique métier complexe, modules isolés.	Chaque PR.
Intégration	SQL réel, bus, cache, stockage, search, IdP simulé.	Transactions/outbox, filtres tenant, index ACL, migrations.	Chaque PR ou merge selon durée.
Contractuels	IdP, connecteurs, providers IA/search.	Pagination, retry, delta, error mapping, structured response.	CI + nightly contre sandbox lorsque possible.
E2E	Angular → API → dépendances de test.	SSO, JIT, admin source, sync, question, citation, suppression.	QA et avant promotion.
Sécurité	SAST, SCA, DAST, secrets, authz, fuzz.	IDOR, cross-tenant, SSRF, injection, token confusion, prompt injection.	PR pour statique ; nightly/release pour dynamique.
Charge	API, sync, ingestion, search, streaming.	Soak, spike, backfill, noisy neighbor et dépendance ralentie.	Avant pilote/GA et changements majeurs.
Résilience	Retries, circuit breakers, reprise et DR.	429 Graph, IA timeout, crash worker, message dupliqué, index indisponible.	QA planifié et game days.
Évaluation IA	Retrieval, groundedness, citations, safety.	Questions attendues, insuffisantes, adversariales et multilingues.	Chaque changement prompt/model/search.

20.2 Jeux de données de test

- Au moins deux tenants avec documents de titres/contenus similaires pour détecter les fuites.
- Utilisateurs et groupes aux ACL qui se recouvrent, se contredisent et changent dans le temps.
- Documents valides, énormes, chiffrés, malformés, malveillants, dupliqués et supprimés.
- Identités invitées, sujets identiques sous issuers différents, claims de groupes tronqués et membre suspendu.
- Questions exactes, sémantiques, ambiguës, sans réponse, avec injection et demandant une donnée interdite.
- Horodatages limites, curseurs expirés, pagination avec mutations et messages dupliqués.

20.3 Matrice de tests de sécurité obligatoire

Surface	Scénarios minimaux	Résultat attendu
Token	Mauvaise audience, issuer forgé, tenant inconnu, expiré, app-only, kid inconnu.	401/403 fermé, aucun accès DB tenant non nécessaire.
API	ID d'autre tenant, mass assignment, pagination abusive, payload énorme.	404/400/413/429 selon cas, aucune fuite.
RBAC	User appelle endpoint admin, Manager élève un rôle, dernier admin se retire.	Refus policy et audit.
ACL	Groupe retiré, ACL inconnue, deny, lien public, citation historique.	Introuvable/non ouvrable dans le SLO.
Connecteur	SSRF, secret invalide, redirect hostile, 429, curseur rejoué.	Blocage, classification et reprise sûre.
Fichier	Zip bomb, parser exploit, extension trompeuse, macro.	Limite/quarantaine, worker protégé.
IA	Instruction dans document, demande de prompt, citation forgée, exfiltration.	Aucune autorisation élargie, citation rejetée, réponse sûre.
Support	Accès sans ticket, durée expirée, autre tenant.	Refus et audit.

20.4 Évaluation RAG

Un jeu « golden » versionné associe question, tenant, principal, documents attendus, éléments de réponse et comportement d'abstention. Il ne doit contenir que des données synthétiques ou explicitement approuvées. Les seuils sont définis avant l'expérience afin d'éviter une validation subjective.

Métrique	But	Gate initial indicatif
Recall@10	Le document pertinent est récupéré.	≥ 0,90 sur cas prioritaires.
ACL precision	Aucun candidat non autorisé.	1,00 obligatoire.
Citation precision	La citation soutient l'affirmation.	≥ 0,90, aucun faux lien.
Groundedness	Réponse dérivée des preuves.	Seuil calibré + revue humaine.
Abstention	Refus correct sans preuve.	≥ 0,90 sur questions sans réponse.
Régression	Nouveau profil vs baseline.	Aucune baisse sécurité ; qualité dans marge approuvée.

20.5 Gestion des défauts et qualité de code

- Un défaut P0 sécurité/isolation bloque toute release et déclenche une analyse d'étendue.
- Les flaky tests sont traités comme défauts ; ils ne sont pas relancés indéfiniment pour obtenir du vert.
- Chaque bug corrigé ajoute un test au niveau le plus bas capable de le reproduire.
- Les décisions structurantes ont un ADR ; les APIs et événements ont une compatibilité documentée.
- La couverture est suivie mais aucun seuil global ne remplace la couverture des invariants critiques.

Critères d'acceptation – Tests

- La CI échoue sur toute fuite inter-tenant, violation ACL ou secret détecté.
- Le parcours SSO → JIT → question → citation est automatisé en E2E.
- Les migrations sont testées depuis la version de production et sur données volumineuses.
- Chaque connecteur certifié passe la même suite contractuelle.
- Un changement de modèle, prompt, chunking ou ranking produit un rapport d'évaluation comparatif.

21. Roadmap de développement

21.1 Hypothèses d'estimation

Les fourchettes supposent une équipe stable de 5 à 7 personnes : 2 à 3 backend, 1 frontend, 1 plateforme, 1 QA/automation, avec architecture/sécurité/produit disponibles. Un sprint représente deux semaines. Les phases peuvent se chevaucher seulement après stabilisation de leurs contrats. Les estimations sont relatives et doivent être recalibrées après la phase 0.

Complexité	Interprétation
S	Module ciblé, dépendances connues, environ 1 sprint d'équipe partielle.
M	Plusieurs use cases et tests, environ 2 à 3 sprints.
L	Module transversal ou intégration externe, environ 3 à 5 sprints.
XL	Chaîne end-to-end à forte incertitude, environ 5 à 8 sprints, à découper.

Phase 0 – Baseline d'architecture et qualité PO

Objectif	Rendre le socle actuel testable, déployable et sûr avant d'ajouter de la donnée client.
Modules	Foundation, Clean Architecture, configuration, erreurs, validation, CI, observabilité minimale.
Prérequis	Dépôt actuel, choix du cloud/stamp de développement et responsables nommés.
Livrables	Projets Domain/Application/Infrastructure/API clarifiés ; tests unitaires/intégration ; Problem Details ; OpenTelemetry ; pipeline CI ; conventions tenant et ADR initiaux.
Complexité	M – 2 à 3 sprints.
Risques	Refactor trop large. Mitigation : migration verticale use case par use case, compatibilité de l'endpoint existant.
Gate	Build reproductible, CI verte, tests d'architecture, aucun secret versionné, déploiement DEV automatisé.

Phase 1 – Tenancy, identité et bootstrap sécurisé

P0

Objectif	Autoriser des entreprises et utilisateurs Entra de manière contrôlée, sans insertion SQL manuelle.
Modules	Multi-tenant, Entra, OrganizationIdentityProvider, ExternalIdentity, JIT, invitations, Current User.
Prérequis	Phase 0 ; application Entra multi-tenant et stratégie d'onboarding.
Livrables	Modèle identité normalisé ; tenant registry ; validation issuer/audience/tenant ; JIT invitation/domain policy ; premier admin ; GET /me/context ; migrations et tests de concurrence.
Complexité	L – 3 à 5 sprints.
Risques	Invités Entra, consentement et claims groupes. Mitigation : périmètre identité explicite et sandboxes de plusieurs tenants.
Gate	Deux tenants réels de test se connectent ; utilisateur non admis refusé ; JIT idempotent ; suspension immédiate.

Phase 2 – Autorisation et administration autonome

P0

Objectif	Permettre au TenantAdmin de gérer le tenant via le produit et faire respecter les permissions côté backend.
Modules	RBAC policies, membres, rôles, invitations, paramètres, audit, feature flags, entilements de base, Angular Admin.
Prérequis	Phase 1 et design minimal de la console.
Livrables	Endpoints admin, policies, audit append-only, liste/pagination, changement rôle/statut, admission policies, configuration tenant et navigation basée sur permissions.
Complexité	L – 3 à 5 sprints.
Risques	Confusion rôle UI/API et sur-administration. Mitigation : matrice normative, tests deny et rôle support séparé.
Gate	Aucune opération admin sans policy ; dernier admin protégé ; parcours d'onboarding réalisable sans accès BD.

Phase 3 – Fondation asynchrone et SDK connecteur

Objectif	Créer le moteur fiable nécessaire aux synchronisations longues et aux intégrations futures.
Modules	Bus/file, outbox, workers, jobs, leases, retries, DLQ, coffre, object storage, connecteur contract.
Prérequis	Phases 0 à 2 ; fournisseurs d'infrastructure choisis.
Livrables	Enveloppe événement, job state machine, scheduling, idempotence, backpressure, secret references, dashboard jobs et suite de conformité connecteur.
Complexité	XL – 5 à 7 sprints.
Risques	Sous-estimer reprise et opérations. Mitigation : failure injection dès le premier worker, pas de framework générique sans cas réel.
Gate	Crash/replay/duplicate démontrés ; DLQ exploitable ; tenant fairness ; secrets rotatifs.

Phase 4 – SharePoint / OneDrive et ingestion sécurisée

Objectif	Synchroniser un corpus Microsoft réel avec contenu, métadonnées, ACL, deltas et suppressions.
Modules	Graph connector, consentement, discovery, sync, parsers, malware scan, document/version/chunk, ACL.
Prérequis	Phase 3 ; tenant Microsoft de test avec matrice d'ACL ; moteur search sélectionné.
Livrables	Onboarding connecteur, sélection sites, initial/delta, types de fichiers MVP, hashes, versionnement, ACL normalisées, purge et réconciliation.
Complexité	XL – 6 à 8 sprints.
Risques	Permissions héritées, throttling, très gros sites, delta expiration. Mitigation : pilote borné, partitions, tests ACL et réconciliation.
Gate	Corpus pilote indexé, suppression/ACL dans SLO, reprise sans doublon, erreurs admin actionnables.

Phase 5 – Recherche hybride et citations

Objectif	Retrouver uniquement les bons passages autorisés et fournir des preuves ouvrables.
Modules	Search adapter, embeddings, index schema, PrincipalSet, hybrid retrieval, ranking, citation resolver.
Prérequis	Phase 4 ; golden dataset et profils embedding/search.
Livrables	Index lexical/vectorel, filtre tenant/ACL, POST /search, snippets, locators, rerank fallback, dashboard qualité.
Complexité	L – 4 à 6 sprints.
Risques	Filtres ACL trop grands, faible recall, coûts embedding. Mitigation : prototype de filtre sur volume final avant verrouillage du moteur.
Gate	ACL precision 1,00 ; Recall@10 et latence atteignent les gates ; tests inter-tenant bloquants.

Phase 6 – RAG et expérience conversationnelle MVP

Objectif	Livrer le produit visible : question, réponse sourcée, historique privé et feedback.
Modules	AI provider, model registry, prompt registry, RAG orchestrator, streaming, conversations Angular/API.
Prérequis	Phase 5 ; contrat fournisseur IA validé ; politiques de données approuvées.
Livrables	Chat streaming, abstention, citations, création/liste/suppression conversation, favoris, feedback, usage et quotas.
Complexité	XL – 5 à 7 sprints.
Risques	Hallucinations, prompt injection, coût/latence. Mitigation : lecture seule, contexte borné, eval gates, fallback compatible et kill switches.
Gate	Évaluation RAG approuvée, citations valides, abstention, aucun secret en prompt/log, SLO TTFT pilote.

Phase 7 – Pilote client et durcissement production

Objectif	Passer d'un MVP fonctionnel à un service opérable avec engagements mesurés.
Modules	Observabilité, SLO, alertes, support, DR, sécurité, performance, RGPD, release et runbooks.
Prérequis	Phase 6 en QA/UAT ; clients pilotes et critères de succès définis.
Livrables	Dashboards, alertes, load/soak/chaos, pentest, backup restore, purge/export, support JIT, runbooks, status communication et canary releases.
Complexité	XL – 5 à 8 sprints.
Risques	Fonctions ajoutées pendant le hardening. Mitigation : feature freeze relative et budgets d'erreur.
Gate	Pentest sans critique, DR exercé, SLO pilote tenu, incidents simulés, DPO/sécurité/ops sign-off.

Phase 8 – Offre entreprise et multi-IdP

Objectif	Réduire le travail manuel d'onboarding et répondre aux exigences entreprise.
Modules	OIDC générique, broker SAML, SCIM, groupes, régions/stamps, partage sécurisé, rôles spécialisés.
Prérequis	Architecture identité de phase 1, retours pilotes et demandes clients qualifiées.
Livrables	Suite conformité IdP, onboarding metadata, migration IdP, SCIM, options de résidence, partage avec intersection d'accès.
Complexité	XL – 6 à 10 sprints par lot.
Risques	Variabilité SAML/SCIM et claims. Mitigation : broker, profils certifiés et contrats de support limités.
Gate	Un fournisseur OIDC non Microsoft et un flux SAML certifiés sans changement du domaine.

Phase 9 – Connecteurs de bases, REST, ERP et CRM

Objectif	Étendre les connaissances au-delà de Microsoft 365 avec le même niveau de sécurité.
Modules	SQL Server, PostgreSQL, Oracle, REST, Dynamics/Salesforce/SAP selon demande.
Prérequis	SDK connecteur mature, ingestion/search stables, clients design partners et réseau privé.
Livrables	Datasets administrés, watermarks/CDC, mappings ACL, agent privé si requis, certifications par connecteur.
Complexité	L à XL par famille – 4 à 8 sprints chacune.
Risques	ACL non transposables et charge sur systèmes critiques. Mitigation : vues lecture seule, fenêtres, quotas et refus si modèle d'accès incomplet.
Gate	Reprise, suppression, ACL, réseau et performance validés avec source réelle représentative.

Phase 10 – Facturation générale et optimisation

Objectif	Industrialiser la monétisation, les coûts et l'expansion du produit.
Modules	Catalogue, subscription, billing provider, invoices, usage ledger, budgets, modèles/routage et capacity planning.
Prérequis	Entitlements et ledger introduits tôt, métriques d'usage fiables, stratégie commerciale.
Livrables	Checkout/contrats selon canal, webhooks idempotents, factures, crédits, alertes coût, marge par tenant/profil.
Complexité	L – 4 à 6 sprints.
Risques	Écarts de comptage et couplage commercial. Mitigation : ledger immuable, réconciliation et EntitlementService.
Gate	Usage réconcilié, webhooks rejouables, états d'impayé sûrs et finance sign-off.

21.2 Chemin critique et parallélisation



Le frontend admin peut démarrer pendant les phases 1-2 sur contrats validés. L'infrastructure managée et les prototypes search/Graph peuvent être explorés en spikes pendant les phases précédentes, mais leur production dépend des gates. Les phases 8-10 sont pilotées par la demande commerciale après un pilote réussi.

22. Risques, hypothèses et décisions ouvertes

22.1 Registre des risques

ID	Risque	Probabilité	Impact	Mitigation / propriétaire
R-01	Fuite inter-tenant par oubli de filtre.	Moyenne	Critique	Conventions, politiques, tests bloquants, canaries ; Architecture + Sécurité.
R-02	ACL SharePoint mal reproduites ou trop lentes.	Élevée	Critique	Prototype sur corpus complexe, fail closed, priorité ACL ; Connectors Lead.
R-03	Qualité RAG insuffisante malgré une UX convaincante.	Élevée	Élevé	Golden set, retrieval d'abord, abstention, retours pilotes ; AI Lead + Product.
R-04	Coûts IA/embedding non maîtrisés.	Moyenne	Élevé	Budgets, batching, déduplication, routage et ledger ; Platform + Product.
R-05	Throttling Graph rallonge onboarding et révocations.	Élevée	Élevé	Delta, Retry-After, fair scheduling, scope borné ; Connectors Lead.
R-06	Architecture multi-IdP anticipée mais non testée.	Moyenne	Moyen	Modèle normalisé dès P1 et certification d'un OIDC secondaire en P8 ; Identity Lead.
R-07	Monolithe modulaire devient couplé.	Moyenne	Moyen	Tests d'architecture, ownership de modules et événements ; Architecture.
R-08	Suppression incomplète dans projections/caches.	Moyenne	Élevé	Catalogue, orchestration, réconciliation et rapport ; Data Lead + DPO.
R-09	Support accède trop largement aux clients.	Faible	Critique	JIT, approbation, redaction, audit et revue ; Security Operations.
R-10	Portée trop large avant le premier pilote.	Élevée	Élevé	MVP Entra + SharePoint + chat privé, gates et feature freeze ; Product Owner.
R-11	Dépendance fournisseur search/IA.	Moyenne	Moyen	Adapters, profils versionnés, export de source de vérité, tests contractuels ; Architecture.
R-12	Text-to-SQL ou agents introduits trop tôt.	Moyenne	Critique	Hors MVP, ADR et threat model obligatoires ; Product + Security.

22.2 Décisions d'architecture retenues

ADR	Décision	Réévaluation
ADR-001	Monolithe modulaire + workers asynchrones, extraction de services sur preuve.	Lorsqu'un module exige scaling, isolation ou cadence indépendante mesurée.
ADR-002	Tenancy partagée par OrganizationId, stamps régionaux et option dédiée future.	Avant premier contrat exigeant base/clé dédiée.

ADR	Décision	Réévaluation
ADR-003	Identité externe normalisée et connexions IdP séparées du membre/tenant.	Après certification OIDC et SAML.
ADR-004	Entitlements/quotas indépendants des noms d'offres.	Lors de l'intégration billing.
ADR-005	Abstractions génération/embedding séparées et ModelRegistry.	À l'ajout d'un second fournisseur réel.
ADR-006	ACL appliquées dans le moteur de recherche avant ranking et contexte.	Non négociable ; technologie search doit s'y conformer.
ADR-007	SQL source indexé via datasets approuvés ; aucun SQL généré par LLM au MVP.	Après threat model et demande client explicite.
ADR-008	Partage conversation désactivé au MVP puis sécurisé par revalidation/intersection.	Après recherche utilisateur et conception de redaction.

22.3 Décisions à prendre avant les phases concernées

Décision	Date limite	Critères	Impact si retard
Cloud, région initiale et services managés.	Début phase 0.	Résidence, équipe, coût, private networking, SLA.	Bloque IaC et CI/CD.
Moteur search/vector.	Avant phase 4.	Filtre ACL à grande cardinalité, hybrid, opérations, coût, région.	Bloque schéma index et prototype volume.
Bus/file et ordonnanceur.	Début phase 3.	DLQ, sessions/partitions, coût, observabilité.	Bloque workers fiables.
Fournisseur IA et embedding.	Avant phase 5.	Politique données, région, qualité, coût, quotas, fallback.	Bloque évaluations et index final.
Modèle commercial pilote.	Phase 2.	Quotas, connecteurs, membres, stockage et support.	Entitlements incohérents.
Politique de rétention et DPA.	Avant données pilote.	Juridictions, clients, fournisseurs et backup cycle.	Interdit ingestion réelle.
Objectifs RPO/RTO/SLO contractuels.	Avant phase 7.	Prix, architecture, support et risque.	GA non approuvable.

23. Définition de terminé

23.1 Pour une fonctionnalité

- Objectif, règles métier, erreurs, permissions, entilements et critères d'acceptation validés.
- Architecture respecte les dépendances, le handler orchestre et les politiques/domain portent les règles.
- Contrats API/événements versionnés et documentés, compatibilité évaluée.
- Tests unitaires, intégration, isolation tenant, deny paths et E2E pertinents réussis.
- Threat model mis à jour ; secrets, PII, logs, rétention et purge traités.
- Métriques, traces, logs, audit, dashboard et alertes nécessaires en place.
- Performance et coût mesurés sous charge représentative.
- Migration, feature flag, rollout, rollback et runbook définis.
- Documentation utilisateur/admin/support et limites connues publiées.
- Product Owner, QA et parties sécurité/opérations donnent le sign-off requis.

23.2 Pour le MVP pilote

- Un tenant Entra est onboardé sans modification manuelle de la base.
- Les employés admis sont provisionnés automatiquement comme User ; les admins gèrent les exceptions.
- Le TenantAdmin configure un connecteur SharePoint/OneDrive et suit la première synchronisation.
- Contenu, versions, suppressions et ACL sont synchronisés et réconciliés.
- Un utilisateur pose une question et reçoit une réponse fondée avec citations ouvrables selon ses droits.
- Une révocation de droit rend le document introuvable dans le SLO.
- Le produit s'abstient sans source suffisante et résiste aux cas de prompt injection définis.
- Historique privé, suppression, quotas et feedback fonctionnent.
- Audit, observabilité, alertes, support et sauvegardes couvrent le pilote.
- Tests sécurité/charge/DR et validation RGPD pilote sont approuvés.

23.3 Pour la disponibilité générale

- SLO tenus pendant une période pilote convenue et budget d'erreur opérationnel.
- CI/CD, canary, rollback, migrations et game days validés.
- Pentest indépendant sans défaut critique ou élevé non traité/accepté.
- RPO/RTO testés, restauration et reindexation chronométrées.
- Export, effacement, offboarding tenant et incident de données exercés.
- Entitlements, usage ledger et coûts par tenant fiables, même si facturation externe différée.
- Runbooks support, sécurité, connecteurs et fournisseurs complets ; astreinte formée.
- Contrats fournisseurs, DPA, régions, rétention et sous-traitants validés.
- Documentation admin/utilisateur et statut de service disponibles.
- Roadmap post-GA priorisée à partir d'usage réel et non d'hypothèses.

23.4 Revue finale de cohérence de cette spécification

Contrôle effectué	Résultat
Autorité d'accès	RBAC produit, entilements et ACL source sont séparés et toujours appliqués côté backend.
Multi-tenant	TenantContext est propagé à la base, aux index, objets, caches, messages, logs et purges.
Multi-IdP	Le modèle cible corrige la limite actuelle d'un IdP porté directement par Organization.
Provisionnement	Le JIT répond au besoin d'ajout automatique sans créer un accès ouvert ni un premier admin opportuniste.
Administration	La console est distincte du chat, permissionnée et suffisante pour éviter les opérations SQL manuelles.
Connecteurs	Authentification, sync, erreurs, reprise, permissions, fréquence et monitoring sont couverts pour chaque famille.
Pipeline	Versionnement, déduplication, ACL, suppression, réconciliation et idempotence sont cohérents.
RAG	La récupération autorisée précède le modèle ; citations, abstention, historique et prompt injection sont traités.
Cycle de vie	Suppression membre, document, connecteur et tenant couvre toutes les projections et sauvegardes selon calendrier.
Exploitation	SLO, logs, métriques, traces, alertes, runbooks, DR, CI/CD et rollback sont spécifiés.
Commercial	Entitlements et ledger sont prévus tôt ; l'intégration de facturation peut être différée sans dette majeure.
Ordonnancement	La roadmap suit les dépendances sécurité → identité → administration → async → ingestion → search → RAG → production.

CONCLUSION DE LA REVUE

Le périmètre est cohérent pour construire le produit de bout en bout. Le seul ensemble volontairement différé est l'exécution d'actions dans les systèmes clients : elle n'est pas nécessaire à la vision d'assistant de connaissance et augmenterait fortement le risque. Toute introduction future suivra un programme agentique séparé.

24. Références et sources normatives

Les références suivantes orientent les décisions ; elles ne remplacent pas la documentation versionnée de chaque fournisseur au moment de l'implémentation.

Sujet	Référence	Usage dans cette spécification
Entra multi-tenant	Microsoft – Convert single-tenant app to multitenant	Validation issuer/tenant et autorité organizations.
Validation des claims	Microsoft – Secure applications and APIs by validating claims	Audience, tenant, sujet et actor.
Access tokens	Microsoft – Access tokens in the identity platform	Jetons destinés à l'API, validation et issuer.
Delta OneDrive/SharePoint	Microsoft Graph – drivetlem delta	Synchronisation incrémentale et changements de partage.
Multi-tenant identity	Azure Architecture Center – Identity in multitenant solutions	Séparation identité, tenant et autorisation.
Prompt injection	OWASP – LLM Prompt Injection Prevention	Séparation instructions/données et contrôles hors modèle.
Risques LLM	OWASP Top 10 for LLM Applications	Threat model IA et réduction des conséquences.
Protection API	OWASP API Security Project	Autorisation objet, ressources et validation.
RGPD	EUR-Lex – Règlement (UE) 2016/679	Minimisation, finalité, conservation et droits.
Architecture	Principes Clean Architecture, SOLID, transactional outbox et idempotent consumers.	Découplage, testabilité et traitements fiables.

24.1 Artefacts de projet à maintenir avec ce document

- Architecture Decision Records et diagrammes de flux de données.
- OpenAPI versionné et catalogue d'événements.
- Modèle de menaces, registre de données et matrice RBAC/ACL.
- Runbooks, SLO, dashboards, alertes et plan de reprise.
- Catalogue de connecteurs et rapports de conformité.
- Golden datasets et rapports d'évaluation RAG.
- Registre de risques, fournisseurs, sous-traitants et exceptions de sécurité.
- Roadmap, release notes, décisions produit et dépréciations.